PRAXISHANDBUCH

Social Engineering & Phishing-Abwehr

Menschen, Manipulation und digitale Angriffe verstehen, erkennen und verhindern

```
Wird etwas verlangt?
nein: informativ, Absender prüfen
ja: Vorgang im Prozess vorgesehen?
nein: Zeitdruck oder Geheimhaltung?
```

DIE ENTSCHEIDUNG FÄLLT IM MOMENT DES VERTRAUENS.

Mit Übungen, Diagrammen, Glossar und Index · Autor: Eugen Becker

Inhaltsverzeichnis

Vorwort 1

Warum der Mensch im Mittelpunkt steht 1

Verbindung von Technik und Verhalten 1

Für wen ist dieses Buch gedacht? 2

Aufbau und Umfang dieser Ausgabe 2

Hinweis zu Übungen und Befehlen 2

Kapitel 1: Grundlagen des Social Engineering 3

Was ist Social Engineering? 3

Der Mensch als Angriffsziel 3

Psychologie der Manipulation 4

Vertrauen und Autorität im Alltag 5

Pretexting und Identitätsvortäuschung 5

Typische Angriffsmuster 5

Praxis: Manipulationsversuche erkennen 6

Kontrollfragen 7

Lernzielkontrolle 8

Kapitel 2: Phishing und seine Varianten 9

Was ist Phishing? 9

Klassisches Phishing 9

Spear-Phishing 10

Whaling 10

CEO-Fraud 10

Business Email Compromise (BEC) 11

Clone Phishing 11

Smishing 11

Vishing 11

Quishing 12

Multi-Channel-Angriffe 12

Entscheidungsbaum zur Bewertung verdächtiger Nachrichten 12

Praxis: Phishing-Nachrichten analysieren 13

Kontrollfragen 13

Lernzielkontrolle 14

Kapitel 3: E-Mail-Angriffe technisch verstehen 15

Was eine E-Mail technisch ist 15
SMTP-Grundlagen 15
Absenderadressen und Spoofing 16
E-Mail-Header im Detail 16
Received-Zeilen lesen 17
Analyse verdächtiger Nachrichten 17
Praxis: E-Mail-Header Schritt für Schritt untersuchen 18
Kontrollfragen 19
Lernzielkontrolle 20

Kapitel 4: E-Mail-Authentifizierung und Domain-Schutz 21

Warum Absender nachgeprüft werden müssen 21
SPF 21
DKIM 22
DMARC 22
Alignment 23
DMARC-Policies stufenweise einführen 23
Reports verstehen 24
Typische Fehlkonfigurationen 24
Praxis: SPF-, DKIM- und DMARC-Einträge prüfen 24
Bewertungsschema 26
Kontrollfragen 27
Lernzielkontrolle 28

Kapitel 5: Unternehmensschutz und Security Awareness 29

Sicherheitskultur 29
Awareness-Konzepte 29
Schulungsplanung 30
Mitarbeitersensibilisierung 30
Meldewege 30
Passwortsicherheit 30
MFA und phishing-resistente Authentifizierung 31
Rollen und Verantwortlichkeiten 32

Technische und organisatorische Maßnahmen 32
Praxis: Ein Awareness-Konzept erstellen 33
Kontrollfragen 34
Lernzielkontrolle 34

Kapitel 6: Erkennung und Incident Response 35
Ein Vorfall im Überblick 35
Anzeichen erkennen 35
Verdächtige E-Mails melden 35
Betroffene Konten sichern 36
Sitzungen und Tokens widerrufen 36
Kennwortwechsel richtig einordnen 36
MFA prüfen 36
Geräte untersuchen 37
E-Mail-Regeln und Weiterleitungen kontrollieren 37
Protokolle sichern 37
Schadensumfang feststellen 37
Kommunikation und Dokumentation 38
Wiederherstellung 38
Lessons Learned 38
Reaktion nach NIST SP 800-61 38
Praxis: Einen Phishing-Vorfall Schritt für Schritt bearbeiten 39
Kontrollfragen 40
Lernzielkontrolle 40

Kapitel 7: Praxisprojekt – Phishing-Abwehr in einem Unternehmen 42
Das Beispielunternehmen 42
Aufgabe 1: Ausgangssituation dokumentieren 43
Aufgabe 2: Bedrohungsanalyse durchführen 43
Aufgabe 3: E-Mail-Schutz prüfen 44
Aufgabe 4: Awareness-Konzept und Meldeprozess 45
Aufgabe 5: Autorisierte Phishing-Simulation planen 46
Aufgabe 6: Ergebnisse auswerten 46
Aufgabe 7: Reaktionsablauf, Priorisierung und Abschlussbericht 47
Bewertungskriterien 47

Kontrollfragen 48
Lernzielkontrolle 49

Recht und Verantwortung 50
Autorisierung als Grundlage 50
Datenschutz 50
Arbeitnehmerdatenschutz und Mitbestimmung 51
Strafrechtliche Grenzen 51
Verantwortungsvolle Sicherheitsforschung 51

Anhang 52
Muster eines Phishing-Incident-Berichts 52
Muster einer Awareness-Richtlinie 52
Checkliste zur E-Mail-Prüfung 53
Glossar 53
Quellenverzeichnis 55
Verzeichnis der Befehle 56
Stichwortverzeichnis 57

Vorwort

Die meisten erfolgreichen Angriffe auf Unternehmen beginnen nicht mit einem Exploit. Sie beginnen mit einer Nachricht, einem Anruf oder einer Person, die etwas tut, weil sie glaubt, es sei richtig. Ein Passwort, das am Telefon herausgegeben wird, eine Überweisung, die auf eine gefälschte Rechnung hin ausgelöst wird, ein Anmeldeformular auf einer Seite, die fast genauso aussieht wie die echte: Für solche Angriffe braucht man keine Schwachstelle in Software. Man braucht eine Person, die im falschen Moment vertraut.

Warum der Mensch im Mittelpunkt steht

Technische Schutzmaßnahmen werden immer besser. Firewalls filtern, Virenschutz erkennt Schadsoftware, und Mehrfaktor-Authentifizierung erschwert den Zugriff auf Konten. Angreifer reagieren darauf, indem sie den Weg über den Menschen wählen. Eine Nachricht, die professionell wirkt und Dringlichkeit vermittelt, umgeht viele technische Filter, weil sie keinen Schadcode enthält. Sie kommt bei einer Person an, die gerade mit vielen Aufgaben beschäftigt ist.

Das ist kein Vorwurf an die Mitarbeiterinnen und Mitarbeiter. Manipulation funktioniert, weil sie an normale, nützliche Eigenschaften anknüpft: Hilfsbereitschaft, Respekt vor Autorität, den Wunsch, Abläufe nicht zu verzögern. Wer diese Mechanismen versteht, kann sie bei sich selbst erkennen.

Verbindung von Technik und Verhalten

Das Buch behandelt beides. Die Kapitel zur Psychologie und zu typischen Angriffsmustern erklären, warum eine Nachricht wirkt. Die Kapitel zu E-Mail-Headern und zu SPF, DKIM und DMARC zeigen, welche technischen Spuren eine Nachricht hinterlässt und wie Domains sich gegen Fälschung schützen. Erst die Verbindung beider Perspektiven macht eine Abwehr wirksam: Eine Technik, die einen Angriff stoppt, ersetzt nicht das aufmerksame Lesen, und ein aufmerksamer Leser erkennt nicht, ob eine Absenderdomain tatsächlich dem Unternehmen gehört.

Für wen ist dieses Buch gedacht?

Das Buch richtet sich an Einsteiger, die verstehen wollen, wie Manipulation funktioniert, an IT-Administratoren, die E-Mail-Sicherheit verantworten, an angehende Fachinformatiker und an alle, die in einer Organisation Verantwortung für Awareness tragen. Vorkenntnisse in Netzwerken sind hilfreich, aber nicht vorausgesetzt. Alle technischen Begriffe werden bei ihrer ersten Verwendung erklärt.

Aufbau und Umfang dieser Ausgabe

Das Buch gliedert sich in einen Grundlagenteil und einen technischen Teil mit einem organisatorischen Abschluss. Kapitel 1 erklärt Social Engineering und die psychologischen Hebel dahinter. Kapitel 2 ordnet die Phishing-Varianten ein. Kapitel 3 zeigt den technischen Aufbau von E-Mails und ihre Header. Kapitel 4 behandelt die Mechanismen zur Authentifizierung von Absendern: SPF, DKIM und DMARC. Kapitel 5 widmet sich Awareness und Authentifizierung für Personen, Kapitel 6 der Reaktion auf einen Vorfall. Kapitel 7 führt in einem Praxisprojekt alle Teile in einem Unternehmensszenario zusammen. Der Recht-Abschnitt und der Anhang schließen das Buch ab.

Diese Ausgabe umfasst bewusst nur diese Themen. Webseiten und Login-Portale, schädliche Anhänge, Analysewerkzeuge, Angriffe außerhalb der E-Mail und Phishing-Simulationen sind einer Folgeausgabe vorbehalten.

Hinweis zu Übungen und Befehlen

Die Übungen arbeiten mit Beispielnachrichten, die zu Lernzwecken erfunden sind. Sie enthalten keine echten Personen, Unternehmen oder Adressen. Die Befehle im Buch sind nach der Dokumentation der jeweiligen Hersteller zusammengestellt und wurden vor der Veröffentlichung nicht praktisch getestet. Prüfe Befehle und Ausgaben deshalb in deiner eigenen Umgebung.

Kapitel 1: Grundlagen des Social Engineering

Lernziele

- Du erklärst, was Social Engineering ist und warum es technische Schutzmaßnahmen umgehen kann.
- Du benennst die psychologischen Hebel, die Angreifer nutzen, und erkennst sie in konkreten Situationen.
- Du unterscheidest Pretexting von anderen Formen der Manipulation und wendest die Erkennungsfragen aus dem Kapitel an.

Was ist Social Engineering?

Social Engineering bezeichnet das gezielte Beeinflussen von Menschen, damit sie eine Handlung ausführen oder eine Information preisgeben, die sie unter normalen Umständen nicht preisgeben würden. Der Begriff umfasst viele Methoden, vom Anruf beim Helpdesk bis zur gefälschten Rechnung. Gemeinsam ist ihnen, dass der Angriff auf eine Entscheidung zielt und nicht auf eine Schwachstelle im System.

Die Entscheidung kann klein sein, etwa ein Passwort zurückzusetzen oder einen Link zu öffnen. Sie kann auch groß sein, etwa eine Zahlung freizugeben. Angreifer brauchen nicht immer einen einzelnen Erfolg. Oft reicht ein erster kleiner Schritt, der den nächsten vorbereitet.

Der Mensch als Angriffsziel

Ein Unternehmen mit guter Technik kann trotzdem leicht zu manipulieren sein, wenn Mitarbeitende Anfragen nicht prüfen. Der Grund liegt nicht in mangelnder Intelligenz. Menschen arbeiten unter Zeitdruck, bearbeiten viele Vorgänge gleichzeitig und haben gelernt, dass Hilfsbereitschaft zum Berufsalltag gehört. Ein Angreifer nutzt diese Routinen aus, indem er eine Anfrage so formuliert, dass sie in den Ablauf passt.

Dazu kommt, dass Menschen Informationen über sich selbst veröffentlichen. Eine Stellenausschreibung, ein Profil in einem sozialen Netzwerk oder ein

Foto auf einer Konferenz können zeigen, wer in welcher Abteilung arbeitet, wer welche Vorgesetzten hat und welche Projekte laufen. Diese Angaben machen eine Manipulation glaubwürdiger.

Psychologie der Manipulation

Manipulation wirkt, wenn sie an Eigenschaften anknüpft, die Menschen normalerweise nützlich sind. Die folgenden Hebel tauchen in fast jedem Angriff auf, auch wenn sie sich nicht immer klar trennen lassen.

Autorität. Menschen folgen Anweisungen, die von einer höher gestellten Person zu kommen scheinen. Eine E-Mail im Namen der Geschäftsführung wird seltener hinterfragt als eine Nachricht eines unbekannten Absenders.

Vertrauen. Wer eine vertraute Person zu kennen glaubt, prüft die Nachricht weniger. Angreifer nutzen Namen, Titel und bekannte Projekte, um Vertrauen zu erzeugen.

Angst. Drohungen mit Kontosperrungen, rechtlichen Folgen oder Datenverlust erzeugen Handlungsdruck. Unter Angst verarbeiten Menschen Informationen schlechter.

Zeitdruck. Eine Frist von wenigen Stunden verhindert Rückfragen. Sätze wie „Die Zahlung muss heute noch raus“ sind ein klassisches Zeichen.

Knappheit. Begrenzte Verfügbarkeit, etwa eines Angebots oder eines Zugangs, erhöht die Bereitschaft zu handeln.

Hilfsbereitschaft. Eine Bitte um Unterstützung in einer Notlage fällt schwer abzulehnen. Angreifer kombinieren das oft mit einer Entschuldigung für die Störung.

Reziprozität. Wer etwas bekommen hat, fühlt sich verpflichtet, etwas zurückzugeben. Ein kleines Geschenk oder ein unerwarteter Gefallen kann diesen Mechanismus auslösen.

Diese Hebel wirken nicht isoliert. Eine typische Nachricht kombiniert zwei oder drei davon: Eine angebliche Führungskraft bittet dringend um Hilfe bei einem vertraulichen Vorgang, und die Frist ist knapp.

Vertrauen und Autorität im Alltag

Vertrauen ist kein Fehler, sondern eine Voraussetzung für Zusammenarbeit. Die Frage ist, woran man Vertrauen festmacht. Wer sich nur auf den Namen oder die Stimme verlässt, kann getäuscht werden. Verlässlicher sind Prozesse: Eine Zahlung wird nur über einen festgelegten Weg freigegeben, und eine Passwortzurücksetzung läuft über einen geprüften Kanal. Solche Regeln entlasten die Einzelperson, denn sie muss nicht mehr im Einzelfall entscheiden, ob eine Anfrage echt ist.

Pretexting und Identitätsvortäuschung

Pretexting bezeichnet eine erfundene Geschichte, mit der sich der Angreifer als jemand ausgibt, der ein berechtigtes Anliegen hat. Typische Vorwände sind ein Techniker, der angeblich einen Fehler beheben muss, ein Lieferant, der eine Rechnung klären möchte, oder eine Kollegin, die aus dem Urlaub einen dringenden Zugriff braucht.

Ein gutes Pretext ist konsistent und passt in den Alltag des Opfers. Der Angreifer kennt Begriffe, Abteilungen und Abläufe. Gerade deshalb ist es wichtig, nicht nach der Plausibilität der Geschichte zu urteilen, sondern nach dem Vorgang: Wird etwas verlangt, das über den üblichen Weg nicht erlaubt ist?

Typische Angriffsmuster

Viele Angriffe folgen wiederkehrenden Mustern. Der Angreifer sammelt zuerst Informationen über das Unternehmen und einzelne Personen. Danach baut er einen Vorwand auf, nimmt Kontakt auf, stellt eine Anfrage und nutzt das Ergebnis. Oft wird die Kommunikation über mehrere Kanäle geführt, etwa erst per E-Mail, dann per Telefon, um die Glaubwürdigkeit zu erhöhen.

Ein Angriff endet nicht immer mit dem ersten Erfolg. Manche Angreifer warten Wochen, bis sich eine günstige Gelegenheit ergibt, etwa die Abwesenheit einer zuständigen Person.

> **Gut zu wissen**
>
> Ein Social-Engineering-Angriff ist nicht allein durch den Inhalt einer Nachricht zu erkennen. Entscheidend ist der Vorgang: Welche Handlung wird verlangt, über welchen Kanal, mit welcher Begründung, und entspricht das dem üblichen Ablauf?

Praxis: Manipulationsversuche erkennen

Lernziel: eine Anfrage anhand von Erkennungsfragen einordnen. **Ausgangssituation:** Eine Mitarbeiterin der Buchhaltung erhält einen Anruf. Eine Person meldet sich als Geschäftsführer, der im Ausland unterwegs sei. Er bittet darum, kurzfristig eine Zahlung an einen neuen Lieferanten freizugeben, und betont, dass er über das Thema niemanden informieren möge, weil die Verhandlung noch vertraulich sei. **Voraussetzungen:** keine technischen. Du brauchst nur das Beispiel und einen Stift. **Aufgabenstellung:** Prüfe die Situation anhand der folgenden Fragen. Notiere für jede Frage, ob die Antwort für einen Angriff spricht, dagegen spricht oder offen bleibt.

1. Verlangt die Anfrage etwas, das über einen Prozess freigegeben werden müsste?
2. Wird Zeitdruck erzeugt?
3. Wird eine Geheimhaltung verlangt, die sonst nicht üblich ist?
4. Gibt es einen zweiten, unabhängigen Kanal zur Prüfung?
5. Stimmt der Vorgang mit dem Zahlungsprozess des Unternehmens überein?

Erwartetes Ergebnis: Die Fragen 1 bis 3 sprechen für einen Angriff. Die Fragen 4 und 5 müssen beantwortet werden, bevor etwas freigegeben wird. Die Mitarbeiterin sollte den Vorgang über den bekannten Kontakt des Geschäftsführers prüfen, nicht über die Nummer, die sie im Anruf erhalten hat. **Überprüfung:** Ist die Entscheidung auch dann richtig, wenn der Anrufer die Wahrheit sagt? Ein guter Prozess schützt in beiden Fällen. **Fehleranalyse:** Viele Lernende nennen als Hauptgrund für einen Angriff die Lautstärke oder den Tonfall des Anrufers. Das ist ein schwaches Signal, denn Stimmen lassen sich imitieren. Der Vorgang und der fehlende zweite

Kanal sind die belastbaren Hinweise. **Sicherheitsbetrachtung:** Übe das Prüfen nicht an realen Personen aus dem eigenen Umfeld. Das Beispiel dient dem Verständnis des Musters.

> **Zusammenfassung**
>
> • Social Engineering zielt auf eine Entscheidung eines Menschen, nicht auf eine technische Schwachstelle.
> • Autorität, Vertrauen, Angst, Zeitdruck, Knappheit, Hilfsbereitschaft und Reziprozität sind die häufigsten Hebel.
> • Pretexting ist die erfundene Begründung, mit der sich ein Angreifer legitimiert.
> • Verlässlicher als der Eindruck einer Nachricht sind Prozesse und ein zweiter, unabhängiger Prüfkanal.

Kontrollfragen

1. Was unterscheidet Social Engineering von einem technischen Angriff? (leicht)
2. Nenne zwei psychologische Hebel und erkläre, wie sie in einer Nachricht wirken. (leicht)
3. Warum ist die Stimme eines Anrufers ein schwaches Prüfkriterium? (mittel)
4. Ein Kollege bittet per Chat um einen Zugang, den er laut Organisationsplan nicht braucht. Welche Fragen stellst du, bevor du reagierst? (mittel)
5. Eine Organisation möchte die Freigabe von Zahlungen automatisieren, um den Zeitdruck zu senken. Welche Chance und welches Risiko entstehen dadurch, und welche Regel sollte gelten? (schwer)

Lösungshinweise: 1. Social Engineering nutzt die Entscheidung eines Menschen, technischer Angriff nutzt einen Fehler im System. 2. Autorität: Eine Anweisung wirkt glaubwürdiger, wenn sie von einer höher gestellten Person zu kommen scheint. Zeitdruck: Eine Frist verhindert Rückfragen. 3. Stimmen lassen sich imitieren, und Angreifer können Vertrauen mit einer glaubwürdigen Stimme aufbauen. 4. Ist der Zugang zur Aufgabe des Kollegen passend? Wer genehmigt ihn? Gibt es einen geregelten

Antragsweg? Ist die Anfrage über den bekannten Kanal bestätigt? 5. Eine Automatisierung senkt den Zeitdruck für Menschen, schützt aber nur, wenn die Freigabe an klare Regeln gebunden ist: Zahlungen an neue Empfänger brauchen eine zweite Prüfung über einen unabhängigen Kanal.

Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] Social Engineering von technischen Angriffen abgrenzen kannst,
- [ ] mindestens vier psychologische Hebel mit Beispielen erklären kannst,
- [ ] Pretexting erkennst und die Erkennungsfragen aus dem Praxisteil anwenden kannst.

Kapitel 2: Phishing und seine Varianten

Lernziele

- Du unterscheidest klassisches Phishing, Spear-Phishing, Whaling, CEO-Fraud und Business Email Compromise.
- Du erkennst Clone Phishing, Smishing, Vishing, Quishing und Multi-Channel-Angriffe anhand ihrer typischen Merkmale.
- Du analysierst eine verdächtige Nachricht anhand eines Entscheidungsbaums.

Was ist Phishing?

Phishing ist der Versuch, über eine gefälschte Nachricht an vertrauliche Daten zu gelangen oder eine Person zu einer Handlung zu bewegen, etwa dem Öffnen eines Links oder dem Ausfüllen eines Formulars. Der Begriff leitet sich vom englischen Wort „fishing“ ab, weil der Angreifer viele Köder auswirft und abwartet, wer anbeißt.

Phishing ist eine Form des Social Engineering. Der Kern ist immer derselbe: Eine Nachricht erweckt den Eindruck, von einer vertrauenswürdigen Stelle zu stammen. Die Varianten unterscheiden sich in Zielgruppe, Vorbereitung und Kanal.

Klassisches Phishing

Beim klassischen Phishing verschickt der Angreifer dieselbe Nachricht an viele Empfänger. Typische Vorwände sind ein angeblich gesperrtes Konto, eine ausstehende Paketzustellung oder eine Zahlung, die bestätigt werden muss. Der Angreifer verwendet einen Link auf eine gefälschte Anmeldeseite oder einen Anhang.

Die Stärke dieser Methode liegt in der Menge. Der Aufwand pro Empfänger ist gering, und selbst eine kleine Erfolgsquote kann sich lohnen. Viele klassische Nachrichten sind deshalb schlecht formuliert, weil es dem Angreifer nicht auf jeden Einzelnen ankommt. Gute Filter erkennen einen Teil

dieser Nachrichten, aber nicht alle.

Spear-Phishing

Spear-Phishing richtet sich an eine bestimmte Person oder einen kleinen Kreis. Der Angreifer recherchiert vorher Name, Rolle, Projekte und Kommunikationsstil. Die Nachricht wirkt deshalb glaubwürdig, weil sie sich auf einen echten Vorgang bezieht.

Die Vorbereitung kostet Zeit, und deshalb trifft Spear-Phishing meist Personen mit besonderem Zugriff, etwa aus Finanzabteilung, Personalwesen oder Administration. Die Erkennung fällt schwerer, weil der Text keine offensichtlichen Fehler hat.

Whaling

Whaling ist Spear-Phishing mit einer Führungskraft als Ziel. Die Bezeichnung spielt auf die große Beute an. Die Nachrichten betreffen oft Verträge, Rechtsfragen, Personalentscheidungen oder vertrauliche Projekte, bei denen eine schnelle Reaktion erwartet wird.

Führungskräfte sind häufiger öffentlich sichtbar, etwa durch Pressemitteilungen oder Vorträge. Diese Informationen nutzt der Angreifer, um Terminologie und Themen nachzuahmen.

CEO-Fraud

CEO-Fraud ist eine Betrugsform, bei der sich der Angreifer als Geschäftsführung ausgibt, um eine Zahlung oder eine vertrauliche Information zu erhalten. Die Anweisung kommt oft per E-Mail oder Telefon, mit dem Hinweis auf Eile und Geheimhaltung. Der Angreifer verlangt, eine Überweisung an ein neues Konto vorzunehmen, etwa wegen eines angeblichen Lieferantenwechsels.

Die wirksamste Gegenmaßnahme ist kein technischer Filter, sondern ein Prozess. Zahlungen an neue Empfänger werden nur nach einer Prüfung über einen unabhängigen, bekannten Kontakt freigegeben. Kapitel 1 zeigt dieses Muster im Praxisteil.

Business Email Compromise (BEC)

Business Email Compromise bezeichnet Angriffe, bei denen ein Angreifer Zugang zu einem echten E-Mail-Konto erhält und es für Betrug nutzt. Der Unterschied zu gefälschten Absendern liegt darin, dass die Nachricht aus einem legitimen Postfach stammt. Das macht die Prüfung des Absenders schwieriger, weil die Adresse stimmt.

Ein typisches Vorgehen ist, dass der Angreifer nach dem Zugriff unauffällig Rechnungen einsieht und eine Zahlung umleitet. Er richtet oft auch Weiterleitungsregeln ein, damit er Antworten mitlesen kann. Das Kapitel 6 behandelt die Erkennung solcher Regeln.

Clone Phishing

Clone Phishing nutzt eine echte, frühere Nachricht als Vorlage. Der Angreifer kopiert den Inhalt, ersetzt aber einen Anhang oder einen Link. Der Empfänger erkennt die Nachricht wieder, weil sie einer früheren ähnelt, etwa einer Rechnung, die er bereits bezahlt hat, oder einer Dokumentenfreigabe.

Die Methode ist gefährlich, weil sie an eine bestehende Kommunikation anknüpft. Wer eine Nachricht prüft, sollte deshalb nicht nur auf den Text schauen, sondern auch auf Absender, Anhänge und Links.

Smishing

Smishing ist Phishing per SMS oder Nachrichtendienst. Die Nachricht ist kurz und enthält meist einen Link. Der Empfänger wird aufgefordert, eine Lieferung zu bestätigen, ein Konto zu verifizieren oder einen Betrag zu begleichen.

Die kurze Form hilft dem Angreifer, weil auf dem Smartphone die Adresszeile des Links oft nur verkürzt angezeigt wird. Der Empfänger sieht dann die vertraute Absenderbezeichnung und nicht die tatsächliche Adresse.

Vishing

Vishing ist Phishing am Telefon. Der Angreifer ruft an, gibt sich als Bank, Helpdesk oder Dienstleister aus und versucht, Zugangsdaten, Codes oder Auskünfte zu erlangen. Die Stimme wirkt unmittelbar, und Rückfragen sind im Gespräch schwerer.

Wichtig ist: Seriöse Stellen fragen nach einem Telefongespräch in der Regel nicht nach Passwörtern oder Einmalcodes. Wer eine solche Anfrage erhält, legt auf und ruft über die offizielle Nummer zurück.

Quishing

Quishing ist Phishing über QR-Codes. Der Code führt zu einer gefälschten Anmeldeseite oder einem Schadlink. Der Vorteil für den Angreifer liegt darin, dass viele E-Mail-Filter den Link im Bild nicht auswerten. Der Empfänger sieht das Ziel erst nach dem Scannen.

Der QR-Code kann auf einem Aushang, in einem Dokument oder in einer E-Mail stehen. Bevor man ihn scannt, sollte man prüfen, woher er stammt und ob er zu einem erwarteten Vorgang gehört.

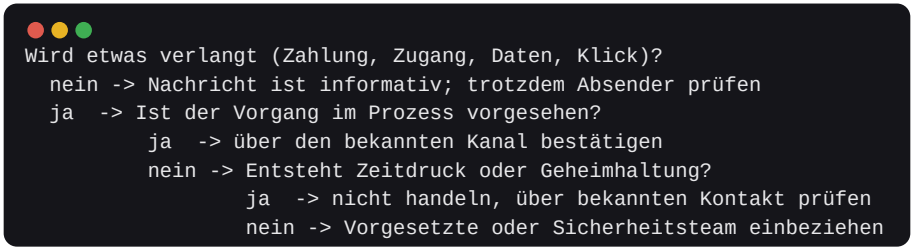
Multi-Channel-Angriffe

Multi-Channel-Angriffe verbinden mehrere Kanäle. Ein Angreifer schreibt zuerst eine E-Mail, kündigt dann einen Anruf an und bestätigt später per SMS. Jeder Kanal wirkt als zusätzliche Bestätigung, obwohl alle vom gleichen Angreifer stammen.

Die Erkennung gelingt, wenn man den Vorgang als Ganzes betrachtet. Ein einzelner Kanal kann unauffällig wirken, die Abfolge verrät den Angriff.

Entscheidungsbaum zur Bewertung verdächtiger Nachrichten

Diagramm 2.1: Entscheidungsbaum für verdächtige Nachrichten



Der Baum ersetzt keine Fachkenntnis. Er zwingt aber zu einer festen Reihenfolge: Erst wird geprüft, ob etwas verlangt wird, dann, ob der Vorgang vorgesehen ist. Erst danach folgt die Frage nach dem Kanal.

Praxis: Phishing-Nachrichten analysieren

Lernziel: eine Nachricht anhand der Varianten und des Entscheidungsbaums einordnen. **Ausgangssituation:** Eine Sachbearbeiterin erhält eine E-Mail mit dem Betreff „Ihre Rechnung Nr. 4711 ist überfällig“. Der Absender trägt den Namen eines bekannten Lieferanten. Die Nachricht enthält einen Link zu einem Zahlungsportal, die Frist endet am Abend. Der Text verweist auf eine frühere Bestellung, die die Empfängerin tatsächlich ausgelöst hat. **Voraussetzungen:** keine technischen. Du brauchst den Entscheidungsbaum aus diesem Kapitel. **Aufgabenstellung:** Ordne die Nachricht einer Variante zu und begründe deine Wahl. Gehe danach den Entscheidungsbaum durch. **Erwartetes Ergebnis:** Die Nachricht zeigt Merkmale von Clone Phishing, weil sie an eine echte Bestellung anknüpft, und von klassischem Phishing, weil ein Link zu einer Zahlung verlangt wird. Der Entscheidungsbaum führt zu einer Prüfung über den bekannten Kontakt des Lieferanten, nicht über den Link. **Überprüfung:** Kann die Sachbearbeiterin den Vorgang mit der Rechnungsnummer im eigenen System abgleichen? Wenn ja, ist die Prüfung belastbar. **Fehleranalyse:** Die Zuordnung zu einer einzigen Variante fällt schwer? Das ist normal. Viele Angriffe mischen Merkmale. Wichtig ist die Begründung, nicht der Name. **Sicherheitsbetrachtung:** Öffne den Link in diesem Beispiel nicht. Beschreibe nur die Merkmale.

> **Zusammenfassung**
>
> - Phishing-Varianten unterscheiden sich in Zielgruppe, Vorbereitung und Kanal, nicht im Grundprinzip.
> - Spear-Phishing, Whaling und CEO-Fraud richten sich an bestimmte Personen. BEC nutzt ein echtes Postfach.
> - Clone Phishing knüpft an frühere Kommunikation an, Smishing, Vishing und Quishing nutzen andere Kanäle.
> - Multi-Channel-Angriffe sind nur erkennbar, wenn man den gesamten Vorgang betrachtet.

Kontrollfragen

1. Was unterscheidet Spear-Phishing von klassischem Phishing? (leicht)

2. Worin liegt der Unterschied zwischen CEO-Fraud und Business Email Compromise? (mittel)

3. Warum ist Quishing für E-Mail-Filter schwerer zu erkennen als ein Link im Text? (mittel)

4. Ein Anrufer bittet am Telefon um einen Einmalcode, angeblich zur Kontoprüfung. Welche Variante liegt vor, und wie reagierst du? (leicht)

5. Eine Führungskraft erhält zuerst eine E-Mail, dann einen Anruf und danach eine SMS mit ähnlichem Inhalt. Welche Erkenntnis ist daraus zu ziehen, und welche Konsequenz folgt für die Prüfung? (schwer)

Lösungshinweise: 1. Spear-Phishing richtet sich an eine bestimmte Person und nutzt Informationen über sie, klassisches Phishing wird an viele Empfänger gleichzeitig geschickt. 2. CEO-Fraud ist ein Betrug mit einer gefälschten Absenderidentität, BEC nutzt ein echtes, kompromittiertes Postfach. 3. Der Link ist als Bild gespeichert und wird vom Filter nicht als Text gelesen. Das Ziel wird erst nach dem Scannen sichtbar. 4. Vishing. Man legt auf und ruft über die offizielle Nummer der Stelle zurück, ohne den Code zu nennen. 5. Mehrere Kanäle mit ähnlichem Inhalt sprechen für einen koordinierten Angriff. Die Prüfung muss den Vorgang als Ganzes betrachten und über einen Kanal erfolgen, der nicht Teil der Kette ist.

Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

[ ] die Varianten Phishing, Spear-Phishing, Whaling, CEO-Fraud und BEC voneinander abgrenzen kannst,

[ ] Clone Phishing, Smishing, Vishing und Quishing an typischen Merkmalen erkennst,

[ ] eine verdächtige Nachricht anhand des Entscheidungsbaums bewertest.

Kapitel 3: E-Mail-Angriffe technisch verstehen

Lernziele

- Du beschreibst den Aufbau einer E-Mail und die Rolle von SMTP beim Versand.
- Du unterscheidest die Absenderangaben im Umschlag (Envelope) von den Angaben im Kopf (Header).
- Du liest einen E-Mail-Header von unten nach oben und erkennst Auffälligkeiten.

Was eine E-Mail technisch ist

Eine E-Mail besteht aus Text in einem festgelegten Format. Die Regeln dafür beschreibt RFC 5322 (Internet Message Format). Eine Nachricht gliedert sich in den Kopf (Header) und den Körper (Body). Der Kopf besteht aus Zeilen mit einem Namen, einem Doppelpunkt und einem Wert, etwa `From:`, `To:` oder `Subject:`. Eine Leerzeile trennt den Kopf vom Körper.

Der Kopf ist für den Menschen gedacht, der die Nachricht liest. Für die Zustellung zählt jedoch noch eine zweite Ebene, die im Kopf nicht sichtbar ist.

SMTP-Grundlagen

Der Versand erfolgt über SMTP (Simple Mail Transfer Protocol), beschrieben in RFC 5321. Ein sendender Server verbindet sich mit dem empfangenden Server und übergibt die Nachricht Schritt für Schritt. Dabei nennt er zuerst den Absender für die Zustellung (Befehl `MAIL FROM`) und danach die Empfänger (Befehl `RCPT TO`). Erst danach folgt der Inhalt mit dem Kopf.

Diese Angaben heißen Umschlag oder Envelope. Der Empfangsserver nutzt sie für die Zustellung und für Rückmeldungen. Mit dem Header hat das zunächst nichts zu tun. Der Header kann also einen anderen Absender nennen als der Umschlag. Genau an dieser Stelle setzen viele Fälschungen an.

> **Gut zu wissen**
>
> Den Absender im Umschlag nennt man auch Envelope-Sender. Der Return-Path im fertigen Header ist eine Angabe, die der Empfangsserver beim Zustellen einträgt. Beide hängen zusammen, sind aber nicht identisch.

Absenderadressen und Spoofing

Spoofing bezeichnet das Vortäuschen eines falschen Absenders. Bei E-Mail gibt es mehrere Ebenen, die gefälscht werden können. Der Anzeigename (Display Name) ist am leichtesten zu ändern. Eine Adresse wie „Geschäftsführung <max@firma-example.de>“ zeigt zuerst den Namen an, die Adresse steht daneben oder nur in Details.

Die Adresse im `From`-Feld kann ebenfalls fremd sein. Wer den Umschlag und das `From`-Feld nicht prüft, verlässt sich auf eine Angabe, die sich leicht ändern lässt. Die Mechanismen, mit denen eine Domain gegen solche Fälschungen geschützt wird, behandelt Kapitel 4.

E-Mail-Header im Detail

Im Header stehen einige Felder, die für die Analyse wichtig sind.

From ist der Absender, der im Lesefenster erscheint. Er wird von DMARC geprüft (Kapitel 4).

Reply-To legt fest, wohin eine Antwort geht. Ein abweichendes Reply-To ist kein Beweis für Betrug, es ist aber ein häufiges Mittel, um Antworten an einen anderen Ort zu leiten.

Return-Path wird vom empfangenden Server eingetragen und nennt die Adresse, an die Zustellfehler gemeldet werden. Stimmt diese Domain nicht mit der Domain im `From`-Feld überein, ist das ein Hinweis, den man prüfen sollte, aber auch bei legitimen Diensten kommt das vor, etwa bei Newslettern.

Message-ID ist eine eindeutige Kennung der Nachricht. Sie wird meist vom sendenden System erzeugt. Der Teil nach dem @ verrät oft, welches System die Nachricht erstellt hat. Eine Message-ID mit einer fremden Domain ist ein Prüfpunkt.

Received ist die wichtigste Zeile für die Herkunft. Jeder Server, der die Nachricht weitergeleitet hat, fügt oben eine solche Zeile hinzu. Die unterste Received-Zeile entspricht dem ersten Server, die oberste dem letzten Schritt vor dem Empfänger. Die Lesereihenfolge ist also umgekehrt zur Zeitfolge.

Authentication-Results fasst zusammen, welche Prüfungen der Empfangsserver durchgeführt hat, etwa für SPF, DKIM und DMARC. Das Format ist in RFC 8601 festgelegt. Dieses Feld ist die schnellste Übersicht über die Authentifizierung, sofern der Server es eintragt.

DKIM-Signature ist vorhanden, wenn die Nachricht signiert wurde. Auch dieses Feld behandelt Kapitel 4.

Received-Zeilen lesen

Eine typische Received-Zeile nennt den Namen des Servers, den Namen des Systems, das die Nachricht übergeben hat, die IP-Adresse und einen Zeitstempel. Die Angaben sind nur so verlässlich wie der Server, der sie geschrieben hat. Ein Angreifer kann eigene Received-Zeilen am Anfang der Nachricht hinzufügen, wenn er die Nachricht selbst versendet. Deshalb zählen die Zeilen, die ein Server des Empfängers hinzugefügt hat, mehr als jene, die vom Absender stammen.

Analyse verdächtiger Nachrichten

Die Analyse folgt einer festen Reihenfolge. Zuerst wird der Header vollständig angezeigt, nicht nur der Betreff. Danach liest man die Received-Zeilen von unten nach oben, um den Weg zu verfolgen. Dann vergleicht man `From`, `Return-Path`, `Reply-To` und die Domain der Message-ID. Schließlich prüft man die Authentication-Results und, wenn vorhanden, die DKIM-Signature.

Ein Befund ist ein Zusammenhang aus mehreren Feldern. Ein abweichendes Reply-To allein sagt wenig, ein abweichendes Reply-To zusammen mit einer fehlgeschlagenen Authentifizierung und einer ungewöhnlichen Received-Kette ist ein belastbarer Hinweis.

Praxis: E-Mail-Header Schritt für Schritt untersuchen

Lernziel: einen Header in der richtigen Reihenfolge lesen und die Felder gegeneinander prüfen. **Ausgangssituation:** Ein Mitarbeiter erhält eine Nachricht mit dem Betreff „Vertragsentwurf Q4“ im Namen eines Partners. Der Anzeigename stimmt. Der Mitarbeiter fragt, ob die Nachricht echt ist. Der Header (vereinfacht und fiktiv, Domains sind Beispiele) lautet:

Beispiel-Header (fiktiv)

```
Received: from mail.partner-example.net (mail.partner-example.net
    [198.51.100.23])
        by mx.firma-example.de with ESMTPS; Tue, 10 Nov 2026
            08:14:02 +0100
Received: from [203.0.113.77] (unbekannt)
        by mail.partner-example.net with ESMTP; Tue, 10 Nov 2026
            08:13:58 +0100
Return-Path: <bounce@kurier-example.org>
From: Lukas Weber <lweber@partner-example.net>
Reply-To: lweber.partner@freemail-example.com
Message-ID: <4f3a9c@kurier-example.org>
Authentication-Results: mx.firma-example.de; spf=fail
    smtp.mailfrom=kurier-example.org;
        dkim=none; dmarc=fail header.from=partner-example.net
Subject: Vertragsentwurf Q4
```

Voraussetzungen: keine technischen. Du brauchst den Header als Text und einen Stift. **Aufgabenstellung:** Lies den Header in folgenden Schritten. Notiere für jeden Schritt, was du siehst und was daraus folgt.

1. Lies die Received-Zeilen von unten nach oben. Der erste Server ist `[203.0.113.77]`, ein unbekanntes System. Der zweite ist der Server des Partners.
2. Vergleiche die Domains. Das `From`-Feld nennt `partner-example.net`, der Return-Path `kurier-example.org`. Die Message-ID trägt ebenfalls `kurier-example.org`.
3. Prüfe das Reply-To. Es zeigt auf eine Freemail-Adresse.
4. Lies die Authentication-Results. SPF ist für den Umschlag fehlgeschlagen, DKIM fehlt, DMARC ist fehlgeschlagen.

Erwartetes Ergebnis: Die Nachricht wurde nicht von der Domain des Partners authentifiziert. Der Anzeigename passt, die technischen Felder nicht. Das ist ein belastbarer Befund, der eine Rückfrage über einen bekannten Kontakt rechtfertigt. **Überprüfung:** Kann ein Dritter allein aus dem Header nachvollziehen, warum die Nachricht als verdächtig gilt? Die Antwort muss auf den Feldern beruhen, nicht auf dem Eindruck des Textes. **Fehleranalyse:** Viele Lernende halten die Received-Zeile mit dem unbekannten System für einen direkten Beweis der Fälschung. Das ist sie nicht. Sie zeigt nur, dass der Weg ungewöhnlich ist. Die Authentifizierung ist der stärkere Hinweis. **Sicherheitsbetrachtung:** Lösche den Header nicht, bevor er dokumentiert ist. Anhänge und Links öffnest du in dieser Übung nicht. Ein Header mit echten Personen gehört nicht in Lehrmaterial, anonymisiere ihn.

> **Zusammenfassung**
>
> • Der Umschlag (MAIL FROM) und der Header (From) sind verschiedene Angaben, und beide können gefälscht sein.
> • Received-Zeilen zeigen den Weg der Nachricht. Die Lesereihenfolge ist umgekehrt zur Zeitfolge.
> • Return-Path, Reply-To und Message-ID geben zusätzliche Hinweise, die man zusammen bewertet.
> • Authentication-Results fasst die Prüfungen zusammen und ist die schnellste Übersicht.

Kontrollfragen

1. Welche Angaben gehören zum Umschlag und welche zum Header? (leicht)

2. In welcher Reihenfolge stehen die Received-Zeilen, und warum liest man sie von unten nach oben? (leicht)

3. Warum ist ein abweichendes Reply-To allein kein sicherer Beweis für Betrug? (mittel)

4. Welche Felder vergleichst du, wenn der Anzeigename eines Absenders stimmt, du aber der Nachricht nicht traust? (mittel)

5. Ein Header zeigt eine korrekte DKIM-Signatur der Domain des Partners, aber einen fehlgeschlagenen DMARC-Test. Was bedeutet das,

und welche Folgerung ist zulässig? (schwer)

Lösungshinweise: 1. Umschlag: MAIL FROM und die Empfänger im SMTP-Dialog. Header: From, Reply-To, Message-ID und die übrigen Felder. 2. Oben steht die neueste Zeile, unten die erste Station. Die Zeitfolge läuft von unten nach oben. 3. Reply-To lässt sich frei setzen, und legitime Dienste nutzen es ebenfalls. 4. From, Return-Path, Reply-To, Message-ID und Authentication-Results. 5. Die DKIM-Signatur belegt eine Signatur der Partner-Domain, die DMARC-Prüfung zeigt aber, dass Absender und signierende Domain nicht übereinstimmen oder die Ausrichtung fehlt. Zulässig ist die Folgerung, dass die Nachricht nicht eindeutig dem Partner zugeordnet werden kann. Eine Schuldzuweisung ist daraus nicht ableitbar.

Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] Umschlag und Header einer E-Mail unterscheiden kannst,
- [ ] Received-Zeilen in der richtigen Reihenfolge liest,
- [ ] einen Header anhand der Felder From, Return-Path, Reply-To, Message-ID und Authentication-Results bewerten kannst.

Kapitel 4: E-Mail-Authentifizierung und Domain-Schutz

Lernziele

- Du erklärst die Aufgaben von SPF, DKIM und DMARC und wie sie zusammenwirken.
- Du erkennst den Unterschied zwischen Absenderprüfung und Ausrichtung (Alignment).
- Du prüfst die DNS-Einträge einer Domain und bewertest typische Fehlkonfigurationen.

Warum Absender nachgeprüft werden müssen

Eine E-Mail trägt keinen eingebauten Echtheitsnachweis. Der Empfänger sieht Absenderangaben, die der Versender frei setzen kann. Die Authentifizierung schließt diese Lücke, indem sie Domains mit kryptografischen oder DNS-basierten Nachweisen verbindet. Drei Verfahren bilden dafür den Standard: SPF, DKIM und DMARC.

Die Verfahren lösen unterschiedliche Fragen. SPF prüft, ob der sendende Server für die Domain zugelassen ist. DKIM prüft, ob die Nachricht unterwegs unverändert blieb und von der Domain signiert wurde. DMARC verbindet beides mit dem Absender im `From`-Feld und legt fest, was bei einem Fehler geschieht.

SPF

SPF (Sender Policy Framework) ist in RFC 7208 beschrieben. Die Domain veröffentlicht im DNS einen TXT-Eintrag, der die zugelassenen Versandsysteme nennt. Der Eintrag beginnt mit `v=spf1`. Danach folgen Mechanismen wie `ip4`, `ip6`, `include`, `a` oder `mx`, die festlegen, welche Systeme senden dürfen. Am Ende steht ein Abschlussmechanismus wie `all`, der festlegt, was mit allen übrigen Systemen geschieht.

Die Abschlussmechanismen unterscheiden sich in der Härte. `-all` lehnt nicht zugelassene Systeme ab, `~all` markiert sie als unsicher, `?all` lässt

sie neutral. Empfänger reagieren darauf unterschiedlich, deshalb ist die Wahl des Abschlusses eine Betriebsentscheidung.

SPF prüft den Umschlag-Absender (MAIL FROM) und nicht den Anzeigenamen. Das ist die wichtigste Grenze des Verfahrens: Eine Nachricht kann SPF bestehen und trotzdem einen fremden `From`-Absender tragen.

RFC 7208 begrenzt die Anzahl der DNS-Abfragen, die eine SPF-Auswertung auslösen darf, auf zehn. Viele `include`-Verweise können diese Grenze überschreiten, dann schlägt die Prüfung fehl.

DKIM

DKIM (DomainKeys Identified Mail) ist in RFC 6376 beschrieben. Der sendende Server signiert bestimmte Kopfzeilen und den Körper der Nachricht mit einem privaten Schlüssel. Die Signatur steht im Feld `DKIM-Signature`. Dort nennt der Absender zwei Angaben: `d=` ist die signierende Domain, `s=` der Selector, also der Name des Schlüssels.

Der öffentliche Schlüssel liegt im DNS unter dem Namen `<selector>._domainkey.<domain>` als TXT-Eintrag. Der Eintrag beginnt mit `v=DKIM1` und enthält den Schlüssel im Feld `p=`. Bei manchen Diensten, etwa Microsoft 365, steht im DNS stattdessen ein CNAME, der auf den Schlüssel verweist. Der Empfänger ruft diesen Schlüssel ab und prüft die Signatur.

DKIM beweist, dass die signierte Domain die Nachricht freigegeben hat und dass die signierten Teile unverändert sind. Es beweist nicht, dass der sichtbare Absender echt ist. Eine Nachricht kann eine gültige Signatur einer anderen Domain tragen.

DMARC

DMARC (Domain-based Message Authentication, Reporting and Conformance) ist in RFC 7489 beschrieben. Es verbindet SPF und DKIM mit dem Absender im `From`-Feld. Die Domain veröffentlicht einen TXT-Eintrag unter `_dmarc.<domain>`, der mit `v=DMARC1` beginnt.

Ein DMARC-Eintrag enthält die Richtlinie im Feld `p=`. Die Werte sind `none` (nur beobachten), `quarantine` (als verdächtig behandeln, etwa in den Spam-Ordner) und `reject` (abweisen). Das Feld `rua=` nennt die Adresse,

an die Berichte gehen. Zusätzlich legen die Felder `aspf=` und `adkim=` fest, ob die Ausrichtung strikt (`s`) oder locker (`r`) geprüft wird.

Die Ausrichtung ist der zentrale Gedanke. DMARC besteht, wenn SPF oder DKIM besteht und die geprüfte Domain zum `From`-Feld passt. Bei lockerer Ausrichtung genügt eine übereinstimmende Organisationsdomain, bei strikter Ausrichtung müssen die Domains identisch sein. So wird verhindert, dass eine korrekt authentifizierte Nachricht einer fremden Domain als Nachricht des Absenders durchgeht.

> **WARNUNG – Sicherheitsrisiko**
>
> RFC 7489 ist der veröffentlichte Stand. Für eine Nachfolgespezifikation, die als „DMARCbis“ bezeichnet wird, liegen mehrere Entwürfe der IETF vor. Prüfe vor einer Umsetzung den aktuellen Status bei der IETF, weil sich Details ändern können.

Alignment

Alignment (Ausrichtung) beschreibt, ob die authentifizierte Domain zur Domain im `From`-Feld gehört. Eine Nachricht kann SPF bestehen, weil sie über einen zugelassenen Server kommt, und dennoch scheitern, wenn der Umschlag-Absender eine andere Domain ist als der sichtbare Absender. Genau diesen Fall erfasst die Ausrichtung.

Für den Praktiker gilt: Ein SPF-Pass allein schützt nicht vor Spoofing im `From`-Feld. Ein DKIM-Pass mit einer fremden Domain auch nicht. Erst die Kombination mit DMARC und passender Ausrichtung macht die Prüfung wirksam.

DMARC-Policies stufenweise einführen

Eine DMARC-Richtlinie wird selten sofort auf `reject` gesetzt. Der übliche Weg beginnt mit `p=none` und einem Bericht an eine eigene Adresse. Die Berichte zeigen, welche Systeme im Namen der Domain senden. Legitime Systeme, die noch nicht zugelassen sind, etwa ein Marketingdienst oder ein Ticketsystem, werden in dieser Phase sichtbar. Danach folgt `quarantine`, zuletzt `reject`.

Ein frühes `reject` kann legitime Post blockieren, wenn ein Versandsystem nicht korrekt authentifiziert. Der Schritt über die Berichte verhindert das.

Reports verstehen

DMARC-Berichte liegen als XML-Dateien vor, die von Empfangsdiensten gesendet werden. Sie enthalten pro Versandquelle die Zahl der Nachrichten und das Ergebnis von SPF, DKIM und DMARC. Eine Quelle, die viele Nachrichten mit fehlgeschlagener Authentifizierung sendet, ist entweder ein falsch konfiguriertes System des Unternehmens oder ein Fälschungsversuch. Die Berichte zeigen das Muster, nicht die Ursache. Die Zuordnung braucht einen Blick auf die Quelle.

Typische Fehlkonfigurationen

Die häufigsten Fehler sind schnell aufgezählt. Mehrere SPF-Einträge in einer Domain führen zum Fehlschlag, weil nur einer gelten darf. Ein SPF-Eintrag über zehn DNS-Abfragen scheitert. Fehlende DKIM-Signaturen bei einem Versandsystem fallen auf, wenn DMARC auf `quarantine` oder `reject` steht. Ein DMARC-Eintrag ohne `rua=` liefert keine Berichte. Ein DKIM-Schlüssel, der im DNS fehlt oder entfernt wurde, lässt die Signatur scheitern.

Praxis: SPF-, DKIM- und DMARC-Einträge prüfen

Lernziel: die DNS-Einträge einer Domain abrufen und nach den Regeln bewerten. **Ausgangssituation:** Eine IT-Administratorin soll prüfen, ob die Domain ihres Unternehmens SPF, DKIM und DMARC korrekt veröffentlicht. Sie kennt die Domain und den Selector aus einer signierten Nachricht des Unternehmens. Für ihre Übung wählt sie eine eigene Testdomain. **Voraussetzungen:** Windows-Client oder Server mit PowerShell (Modul DnsClient, bei Windows 8 und Windows Server 2012 oder neuer enthalten). Die Abfragen erfolgen über das öffentliche DNS. Es werden nur öffentlich abrufbare Einträge gelesen.

Schritt 1: SPF-Eintrag abrufen.

Befehle zu Schritt 1 (SPF)

```
PS> Resolve-DnsName -Name example.com -Type TXT | Where-Object {
```

```
    $_.Strings -match '^v=spf1' }
```

Erklärung: `Resolve-DnsName` fragt die DNS-Einträge eines Namens ab. `-Name` nennt die Domain, `-Type TXT` begrenzt auf TXT-Einträge, in denen SPF steht. Der `Where-Object`-Filter zeigt nur Einträge, deren Text mit `v=spf1` beginnt. Die Eigenschaft `Strings` enthält den Text des Eintrags.

Schritt 2: DMARC-Eintrag abrufen.

Befehle zu Schritt 2 (DMARC)

```
PS> Resolve-DnsName -Name _dmarc.example.com -Type TXT
```

Erklärung: Der Name `_dmarc` ist ein Unterbereich der Domain. Die Abfrage zeigt die Richtlinie.

Schritt 3: DKIM-Schlüssel abrufen. Den Selector entnimmst du dem Feld `s=` in der `DKIM-Signature` einer echten Nachricht der Domain.

Befehle zu Schritt 3 (DKIM)

```
PS> Resolve-DnsName -Name <selector>._domainkey.example.com -Type
    TXT
```

Erklärung: Der Platzhalter `<selector>` wird durch den Namen aus der Signatur ersetzt. Die Abfrage zeigt den öffentlichen Schlüssel im Feld `p=`.

Microsoft 365 und CNAME: Bei Microsoft 365 verweist der Selector häufig auf einen CNAME-Eintrag, der auf den eigentlichen Schlüssel in einer Microsoft-Domain zeigt. Die TXT-Abfrage liefert dann keinen Schlüssel. Frage in diesem Fall den CNAME ab und löse das Ziel anschließend mit einer TXT-Abfrage auf:

Befehle zu Schritt 3 (CNAME)

```
PS> Resolve-DnsName -Name <selector>._domainkey.example.com -Type
    CNAME
```

Erklärung: Der Typ CNAME zeigt das Ziel des Eintrags. Die Ergebnisse der TXT-Abfrage auf dieses Ziel zeigen den Schlüssel. Ob der Selector bei deinem Mandanten als CNAME veröffentlicht ist, steht in der Dokumentation

des Anbieters.

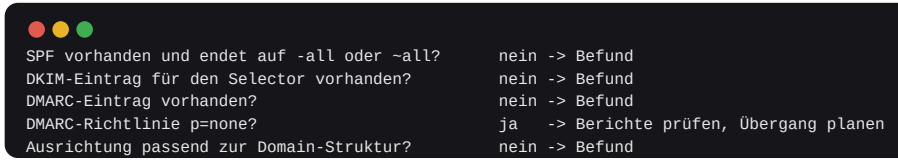
Alternative auf der Kommandozeile: `nslookup.exe -type=TXT _dmarc.example.com` liefert dieselbe Information. In PowerShell rufst du das Programm mit `.exe` auf, weil `nslookup` dort als Alias für `Resolve-DnsName` belegt sein kann.

Erwartetes Ergebnis: Der SPF-Eintrag beginnt mit `v=spf1` und endet mit einem Abschlussmechanismus wie `-all` oder `~all`. Der DMARC-Eintrag beginnt mit `v=DMARC1` und enthält `p=` mit `none`, `quarantine` oder `reject`. Der DKIM-Eintrag beginnt mit `v=DKIM1` und enthält `p=` mit dem Schlüssel.

Überprüfung: Stimmt der Selector aus der Signatur mit dem abgerufenen Eintrag überein? Wenn nicht, ist die Signatur über den DNS-Eintrag nicht prüfbar. **Fehleranalyse:** Die SPF-Abfrage liefert keinen Treffer? Dann fehlt der Eintrag, oder er steht auf einer anderen Ebene. Prüfe die Schreibweise und den Domainnamen. Der DKIM-Eintrag fehlt? Der Selector ist falsch oder der Schlüssel wurde nicht veröffentlicht. Ein CNAME-Eintrag verweist auf eine andere Stelle, die Abfrage folgt ihm in der Regel automatisch. **Sicherheitsbetrachtung:** Die Abfragen lesen nur öffentliche DNS-Einträge. Sie verändern nichts. Verändere niemals DNS-Einträge einer fremden Domain, und nutze für eigene Tests eine Domain, die dir gehört.

Bewertungsschema

Diagramm 5.1: Bewertung der E-Mail-Authentifizierung einer Domain



Das Schema prüft die Reihenfolge der Bausteine. Ein fehlender Baustein macht die anderen nicht wirkungslos, aber er lässt Lücken, die ein Angreifer nutzt.

Zusammenfassung

- SPF prüft den Versandsystem-Zugang über den Umschlag-Absender, DKIM die Signatur, DMARC die Ausrichtung zum sichtbaren Absender.
- Ein SPF-Pass allein oder ein DKIM-Pass mit fremder Domain schützt nicht vor Spoofing im `From`-Feld.
- DMARC wird stufenweise eingeführt: von `none` über `quarantine` bis `reject`, mit Auswertung der Berichte.
- Die Prüfung mit `Resolve-DnsName` liest nur öffentliche Einträge.

Kontrollfragen

1. Was prüft SPF, und welcher Absender steht dabei im Mittelpunkt? (leicht)
2. Welche Bedeutung hat das Feld `p=` in einem DMARC-Eintrag? (leicht)
3. Warum reicht ein gültiger DKIM-Pass nicht aus, um den Absender zu bestätigen? (mittel)
4. Eine Domain setzt `p=reject` ohne vorherige Auswertung der Berichte. Welche Folge ist wahrscheinlich, und wie hätte man sie vermeiden können? (mittel)
5. Ein Empfänger meldet, dass eigene Nachrichten im Spam landen, obwohl SPF und DKIM bestehen. Welche Prüfung ist als Nächstes sinnvoll? (schwer)

Lösungshinweise: 1. SPF prüft, ob der sendende Server für die Domain des Umschlag-Absenders zugelassen ist. Im Mittelpunkt steht der Umschlag, nicht der Anzeigename. 2. Es legt die Richtlinie fest: `none` beobachtet nur, `quarantine` behandelt Nachrichten als verdächtig, `reject` weist sie ab. 3. DKIM zeigt, dass eine Domain signiert hat, nicht, dass sie zum sichtbaren Absender gehört. Ausrichtung und DMARC prüfen diese Zuordnung. 4. Legitime Versandsysteme ohne korrekte Authentifizierung werden abgewiesen, etwa Ticket- oder Marketingdienste. Die Auswertung der Berichte mit `p=none` zeigt diese Quellen vorher. 5. Die Berichte prüfen, welche Quelle die Nachrichten sendet und wie die Ausrichtung ist. Danach wird die Richtlinie für die Ausrichtung und die Inhalte bewertet. Die Zustellung wird ebenfalls geprüft, da Spam-Filter weitere Kriterien verwenden.

Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] SPF, DKIM und DMARC in ihrer Aufgabe beschreiben kannst,
- [ ] den Unterschied zwischen Authentifizierung und Ausrichtung erklären kannst,
- [ ] SPF-, DKIM- und DMARC-Einträge mit `Resolve-DnsName` abrufst und nach dem Schema bewertest.

Kapitel 5: Unternehmensschutz und Security Awareness

Lernziele

- Du erklärst, warum Awareness eine Daueraufgabe ist und welche Elemente ein Konzept braucht.
- Du unterscheidest phishing-resistente Authentifizierung von schwächeren Verfahren wie SMS-Codes.
- Du beschreibst Rollen, Meldewege und technische Maßnahmen, die einen Phishing-Angriff abfangen.

Sicherheitskultur

Eine Organisation ist nicht sicher, weil sie Regeln hat. Sie ist sicher, wenn die Regeln im Alltag gelebt werden. Die Sicherheitskultur beschreibt, wie Mitarbeitende mit Unsicherheit umgehen: Sie fragen nach, wenn etwas ungewöhnlich wirkt, sie melden Fehler, ohne Angst vor Sanktionen, und sie erwarten, dass Führungskräfte Prozesse selbst einhalten.

Eine Kultur entsteht nicht durch Plakate. Sie hängt davon ab, wie Vorgesetzte reagieren, wenn jemand auf einen Fehler hinweist. Wer Meldungen bestraft, bekommt weniger Meldungen und damit weniger Information über den eigenen Zustand.

Awareness-Konzepte

Awareness meint das Bewusstsein für Gefahren und das Wissen, wie man reagiert. Ein Konzept beantwortet vier Fragen: Welche Verhaltensweisen sollen sich ändern, für wen gilt das, mit welchen Mitteln wird es erreicht, und woran misst man den Erfolg?

Ein Konzept ohne Messgröße bleibt eine Absicht. Gängige Größen sind die Zahl der gemeldeten verdächtigen Nachrichten, die Zeit bis zur Meldung und der Anteil der Mitarbeitenden, die einen Trainingsbaustein abgeschlossen haben. Die Zahl der Klicks in einer Simulation ist dagegen eine schwache Größe. Simulationen behandelt ein späterer Teil dieser Reihe.

Schulungsplanung

Schulungen wirken, wenn sie wiederholt werden. Einmalige Vorträge werden vergessen. Ein sinnvoller Plan verteilt kurze Einheiten über das Jahr, passt Inhalte an die Rolle an und greift aktuelle Fälle aus dem Unternehmen oder der Presse auf, sofern sie anonymisiert sind.

Zielgruppen unterscheiden sich. Die Buchhaltung braucht Wissen über Zahlungsfreigaben, die Personalabteilung über Bewerbungs- und Dokumentenbetrug, die Führungskräfte über CEO-Fraud. Ein Einheitsprogramm erreicht selten alle.

Mitarbeitersensibilisierung

Sensibilisierung bedeutet, Mitarbeitende zu befähigen, nicht sie zu beschämen. Wer nach einer Simulation öffentlich bloßgestellt wird, lernt vor allem, Fehler zu verbergen. Hilfreicher sind Rückmeldungen, die erklären, welche Merkmale die Nachricht hatte, und welche Schritte richtig gewesen wären.

Meldewege

Ein Meldeweg muss so einfach sein, dass er in der Hektik funktioniert. Typischerweise gibt es eine Meldeschaltfläche im Postfach oder eine feste Adresse des Sicherheitsteams. Die Meldung braucht keine Analyse vom Absender, er reicht die Nachricht als Anhang weiter oder nutzt die Funktion im Mail-Client.

Wichtig ist die Rückmeldung. Wer meldet und nie eine Antwort erhält, meldet beim nächsten Mal nicht mehr. Eine kurze Bestätigung mit dem Ergebnis genügt.

Passwortsicherheit

Passwörter bleiben ein Schutzmechanismus, auch wenn sie allein nicht genügen. Die Empfehlungen des NIST in der Spezifikation SP 800-63B haben sich in den letzten Jahren verschoben. Nach dem Stand der Revision 4 aus dem Jahr 2025 gilt:

- Eine Mindestlänge von acht Zeichen ist die Untergrenze, längere Passwörter und Passphrasen sind vorzuziehen.

- Erzwungene Komplexitätsregeln, etwa Sonderzeichen-Pflicht, gelten nicht mehr als wirksam.
- Ein Zwangswechsel in festen Abständen ist nicht erforderlich. Ein Wechsel ist nötig, wenn ein Passwort bekannt geworden sein kann.
- Passwörter werden gegen Listen bekannter und kompromittierter Kennwörter geprüft.
- Das Einfügen aus einem Passwortmanager darf nicht blockiert werden.

Diese Angaben stammen aus Sekundärquellen zur Revision 4. Vor einer Richtlinie prüfst du den Originaltext im NIST-Dokument.

> **Gut zu wissen**
>
> Ein Passwort, das gut gewählt ist, schützt nicht vor einer Eingabe auf einer gefälschten Seite. Deshalb ist die Passwortrichtlinie nur ein Teil der Abwehr, der zweite Teil ist die Authentifizierung selbst.

MFA und phishing-resistente Authentifizierung

Mehrfaktor-Authentifizierung (MFA) verlangt zusätzlich zum Passwort einen zweiten Nachweis, etwa einen Code oder eine Bestätigung. Die Verfahren unterscheiden sich stark in ihrer Widerstandsfähigkeit gegen Phishing.

Ein SMS-Code kann auf einer gefälschten Seite eingegeben und an den Angreifer weitergeleitet werden, ebenso ein zeitbasierter Einmalcode aus einer App. Ein Angreifer kann beide in Echtzeit an die echte Seite weitergeben. Eine Bestätigungsanfrage per Push ist dagegen anfällig für Ermüdung: Wer täglich viele Anfragen erhält, bestätigt eine unerwartete irgendwann. Abhilfe schafft das Abgleichen einer angezeigten Zahl, die der Nutzer auf dem Anmeldebildschirm eingibt.

Phishing-resistente Verfahren binden die Anmeldung an die Domain. FIDO2 und WebAuthn verwenden einen Schlüssel, der nur für die echte Seite Signaturen erzeugt. Eine gefälschte Domain erhält daher keine gültige Antwort. Passkeys sind eine Form dieser Technik. Sie können auf dem Gerät gebunden oder über ein Konto synchronisiert werden. Beide Varianten sind phishing-resistent, unterscheiden sich aber in der Wiederherstellung bei Geräteverlust.

Rollen und Verantwortlichkeiten

Awareness und Abwehr betreffen mehrere Stellen. Die Geschäftsführung legt Prioritäten fest und stellt Mittel bereit. Die IT verantwortet die technischen Schutzmaßnahmen wie E-Mail-Authentifizierung und Mehrfaktor-Verfahren. Die Personalabteilung begleitet Schulungen und Richtlinien. Führungskräfte prüfen, ob Prozesse eingehalten werden. Alle Mitarbeitenden melden verdächtige Vorgänge.

Eine klare Zuständigkeit für Entscheidungen in einem Vorfall ist wichtig. Wer darf einen Account sperren, wer entscheidet über eine Meldung an Behörden, wer informiert die Belegschaft? Diese Fragen werden vorab beantwortet, nicht im Vorfall.

Technische und organisatorische Maßnahmen

Technische Maßnahmen gegen Phishing umfassen die E-Mail-Authentifizierung aus Kapitel 4, einen Spam- und Schadfilter, phishing-resistente Anmeldung, die Einschränkung von Weiterleitungsregeln und Browserschutz. Organisatorische Maßnahmen sind die Richtlinie für Zahlungen, ein dokumentierter Meldeweg, ein Ablauf für Passwortrücksetzungen über einen geprüften Kanal und regelmäßige Schulungen.

Keine der Maßnahmen wirkt allein. Die Kombination ist entscheidend, weil jede Schicht Fehler der anderen auffängt.

Praxis: Ein Awareness-Konzept erstellen

Lernziel: ein Konzept mit Zielen, Zielgruppen, Maßnahmen und Messgrößen entwerfen. **Ausgangssituation:** Ein Unternehmen mit 30 Mitarbeitenden in Verwaltung, Vertrieb und Technik hat in den letzten zwölf Monaten zwei Vorfälle gemeldet. In einem Fall wurde eine gefälschte Rechnung bezahlt, im anderen gab eine Mitarbeiterin ein Passwort auf einer Anmeldeseite ein. Die Geschäftsführung bittet um ein Konzept für das nächste Jahr. **Voraussetzungen:** keine technischen. Du brauchst eine Tabelle und die Angaben oben. **Aufgabenstellung:** Erstelle eine Tabelle mit den Spalten Ziel, Zielgruppe, Maßnahme, Häufigkeit, Messgröße und Verantwortliche. Lege mindestens vier Zeilen an. Jede Maßnahme soll auf einen der beiden Vorfälle zurückgehen. **Erwartetes Ergebnis:** Die Zeile zur Zahlungsfreigabe richtet sich an die Buchhaltung und setzt eine feste Prüfung über einen zweiten Kanal um. Die Zeile zur Anmeldung richtet sich an alle Mitarbeitenden und setzt auf phishing-resistente Verfahren sowie auf eine Schulung zu Anmeldeseiten. Messgrößen sind etwa die Zahl der Meldungen und die Zeit bis zur Meldung, nicht die Zahl der Klicks. **Überprüfung:** Ist jede Maßnahme einem Vorfall zugeordnet, und ist jede Messgröße messbar? Eine Maßnahme ohne Messgröße gehört in die Tabelle nur mit Begründung. **Fehleranalyse:** Viele Entwürfe enthalten nur Schulungen. Ergänze technische Maßnahmen und Prozesse, sonst bleibt der Schutz vom Verhalten einzelner Personen abhängig. **Sicherheitsbetrachtung:** Ein Konzept mit Namen einzelner Mitarbeitender, die einen Vorfall verursacht haben, gehört nicht in den Umlauf. Beschreibe den Vorfall anonym.

> **Zusammenfassung**
>
> - Awareness braucht Ziele, Zielgruppen, Wiederholung und Messgrößen, und sie verlangt eine Kultur, in der Meldungen erwünscht sind.
> - Phishing-resistente Verfahren wie FIDO2 und Passkeys binden die Anmeldung an die echte Domain. SMS-Codes und Einmalcodes können in Echtzeit weitergegeben werden.
> - Die Passwortrichtlinie folgt dem Stand von NIST SP 800-63B und verzichtet auf Zwangswechsel ohne Anlass.
> - Technische und organisatorische Maßnahmen ergänzen sich, keine wirkt allein.

Kontrollfragen

1. Welche vier Fragen beantwortet ein Awareness-Konzept? (leicht)
2. Warum ist eine Bestätigungsanfrage per Push anfällig, und welche Gegenmaßnahme hilft? (mittel)
3. Warum binden FIDO2-Schlüssel und Passkeys die Anmeldung an die Domain? (mittel)
4. Ein Mitarbeiter meldet nach einer Simulation, dass er auf einen Link geklickt hat. Wie reagiert eine gute Organisation, und warum? (mittel)
5. Die Geschäftsführung fordert, dass alle Passwörter alle 90 Tage gewechselt werden. Welche Abwägung ist nach SP 800-63B zu treffen, und welche Alternative schlägst du vor? (schwer)

Lösungshinweise: 1. Welche Verhaltensweisen sich ändern sollen, für wen, mit welchen Mitteln und woran der Erfolg gemessen wird. 2. Müdigkeit führt dazu, dass Anfragen unbesehen bestätigt werden. Abhilfe ist die Abfrage einer angezeigten Zahl, die auf dem Anmeldebildschirm eingegeben wird. 3. Der Schlüssel erzeugt Signaturen nur für die Domain, mit der er registriert wurde. Auf einer gefälschten Domain wird deshalb keine gültige Antwort erzeugt. 4. Die Meldung wird gewürdigt, weil sie Information liefert. Eine Sanktion würde künftige Meldungen unterdrücken. Danach folgen Schutzmaßnahmen für das Konto. 5. Ein erzwungener Wechsel in festen Abständen verleitet zu schwächeren Varianten und ist nach SP 800-63B nicht erforderlich. Alternative: Wechsel nur bei Verdacht, Abgleich mit Passwortlisten und phishing-resistente Anmeldung.

Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

- [ ] ein Awareness-Konzept mit Messgrößen beschreiben kannst,
- [ ] phishing-resistente von schwächeren Mehrfaktor-Verfahren unterscheidest,
- [ ] technische und organisatorische Maßnahmen einer Organisation zuordnest.

Kapitel 6: Erkennung und Incident Response

Lernziele

- Du erkennst typische Anzeichen eines Phishing-Angriffs, auch wenn der Angreifer bereits Zugang hat.
- Du beschreibst die Schritte von der Eindämmung bis zur Wiederherstellung und ordnest sie den Funktionen von NIST SP 800-61 zu.
- Du begründest, warum ein Kennwortwechsel allein nicht ausreicht.

Ein Vorfall im Überblick

Ein Phishing-Vorfall beginnt oft unauffällig. Eine Mitarbeiterin gibt ihre Daten auf einer gefälschten Seite ein und merkt es nicht. Erst später fallen Auffälligkeiten auf: Nachrichten, die sie nicht verschickt hat, Anmeldungen aus einem fremden Land, Regeln im Postfach, die Nachrichten an eine externe Adresse weiterleiten.

Der Angreifer nutzt den Zugang selten sofort. Er sichtet Postfächer, sucht nach Rechnungen und richtet Mechanismen ein, die ihm weiteren Zugang sichern. Die Reaktion muss deshalb mehr erfassen als das eine Konto.

Anzeichen erkennen

Typische erste Anzeichen sind Meldungen von Kolleginnen und Kollegen über verdächtige Nachrichten im eigenen Namen, Anmeldewarnungen von Diensten, eine neue Methode zur Mehrfaktor-Authentifizierung, die niemand selbst eingerichtet hat, und Weiterleitungsregeln im Postfach. Jedes Anzeichen allein kann harmlos sein. Die Häufung entscheidet.

Verdächtige E-Mails melden

Die Meldung ist der erste Schritt der Reaktion. Sie muss die Nachricht als Anhang oder über die Meldefunktion erreichen, damit das Sicherheitsteam die Kopfzeilen auswerten kann. Mitarbeitende sollten die Nachricht nicht weiterleiten, nicht antworten und keine Links öffnen.

Betroffene Konten sichern

Das betroffene Konto wird als Erstes gesichert. Dazu gehören das Sperren der Anmeldung, falls das nötig ist, und die Sicherung des Postfachs für die spätere Analyse. Die Sicherung darf nichts löschen, was für die Untersuchung wichtig ist.

Sitzungen und Tokens widerrufen

Nach einer erfolgreichen Anmeldung auf einer gefälschten Seite besitzt der Angreifer unter Umständen ein gültiges Sitzungs-Token. Dieses Token bleibt wirksam, auch wenn das Passwort geändert wird. Deshalb müssen bestehende Sitzungen des Kontos aktiv beendet werden. Die Administrationsoberfläche des eingesetzten Dienstes bietet dafür in der Regel eine entsprechende Funktion. Ihre genaue Bezeichnung ist in der Herstellerdokumentation nachzulesen.

Kennwortwechsel richtig einordnen

Ein Kennwortwechsel ist sinnvoll, aber er allein beendet den Angriff nicht. Wenn der Angreifer ein Token besitzt, oder wenn er eine eigene Mehrfaktor-Methode registriert hat, bleibt der Zugang bestehen. Der Wechsel gehört deshalb zu einer Reihe von Schritten: Sitzungen beenden, Mehrfaktor-Methoden prüfen, Regeln kontrollieren, dann das Kennwort ändern.

MFA prüfen

Die Mehrfaktor-Einstellungen des Kontos werden auf unbekannte Methoden untersucht. Ein Angreifer, der das Konto übernommen hat, trägt oft eine eigene Methode ein, damit er auch nach einem Kennwortwechsel wieder hineinkommt. Jede Methode, die niemand selbst eingerichtet hat, wird entfernt.

Geräte untersuchen

Wurde das Gerät der betroffenen Person genutzt, um die Anmeldedaten einzugeben, oder ist Schadsoftware möglich, wird es untersucht. Die Untersuchung folgt den Grundsätzen aus dem Handbuch Digitale Forensik dieser Reihe: Image, Hashwert und Dokumentation, bevor Änderungen vorgenommen werden. Bei klaren Hinweisen auf Schadsoftware wird das Gerät isoliert.

E-Mail-Regeln und Weiterleitungen kontrollieren

Weiterleitungsregeln sind ein häufiges Mittel, um Zugriff zu behalten. Eine Regel kann alle Nachrichten mit bestimmten Begriffen an eine externe Adresse senden oder sie in einen versteckten Ordner verschieben. Die Regeln des Postfachs werden über die Administrationsoberfläche oder über PowerShell für Exchange Online geprüft. Mit `Get-InboxRule` in der Exchange-Online-PowerShell lassen sich die Regeln eines Postfachs abfragen. Vorher stellst du eine Verbindung her (`Connect-ExchangeOnline`) und nennst das Postfach mit `-Mailbox`. Dafür sind passende Berechtigungen nötig. Prüfe Befehle und Parameter vor der Verwendung in deiner Umgebung.

Protokolle sichern

Anmeldeprotokolle, Änderungsprotokolle des Verzeichnisses und die Protokolle des Postfachs werden gesichert, bevor sie durch die Aufbewahrungsfrist verloren gehen. Der Zeitraum, für den Protokolle verfügbar sind, unterscheidet sich je nach Dienst und Lizenz. Diese Frist ist früh zu klären.

Schadensumfang feststellen

Die Analyse fragt, was der Angreifer gesehen und getan hat: welche Nachrichten gelesen wurden, ob Dateien geöffnet oder geteilt wurden, ob Zahlungen angestoßen wurden. Die Antworten bestimmen, welche Personen informiert werden müssen und ob weitere Konten betroffen sind.

Kommunikation und Dokumentation

Die Kommunikation folgt einem festgelegten Plan. Die Belegschaft erhält eine kurze Information, die Anleitung enthält und keine Schuldzuweisung. Externe Partner werden informiert, wenn Daten oder Zahlungen betroffen sind. Die Dokumentation hält Zeitpunkte, Entscheidungen und Verantwortliche fest. Ein Musterbericht folgt in einem späteren Teil dieser Reihe.

Wiederherstellung

Die Wiederherstellung umfasst alle Maßnahmen, die den Zugang sicher beenden: Konten neu eingerichtet oder bereinigt, Mehrfaktor-Methoden neu registriert, Regeln entfernt, Geräte geprüft oder ersetzt. Die Rückkehr zum Normalbetrieb erfolgt erst, wenn diese Schritte abgeschlossen sind.

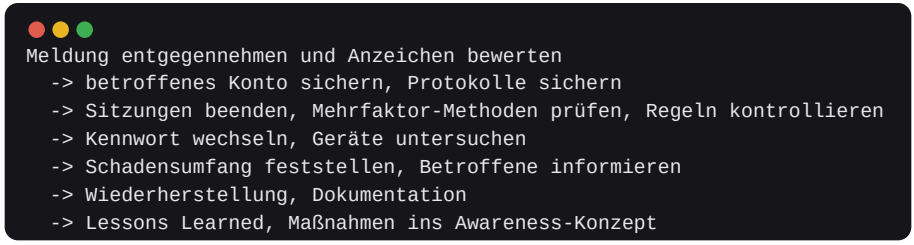
Lessons Learned

Nach dem Vorfall werden die Ursachen untersucht. Wurde die Nachricht ausreichend erkannt? Hat der Meldeweg funktioniert? War die Mehrfaktor-Methode phishing-resistent? Die Antworten führen zu konkreten Maßnahmen, die in das Awareness-Konzept aus Kapitel 5 einfließen.

Reaktion nach NIST SP 800-61

NIST SP 800-61 Revision 3 aus dem Jahr 2025 ersetzt die Revision 2 und ordnet die Empfehlungen den Funktionen des Cybersecurity Framework 2.0 zu. Für einen Phishing-Vorfall sind vor allem Erkennen (Detect), Reagieren (Respond) und Wiederherstellen (Recover) relevant. Vorbereitung und Lernen zählen zu den Funktionen Govern und Identify, die in diesem Buch im Kapitel 5 behandelt werden.

Diagramm 11.1: Ablauf der Reaktion auf einen Phishing-Vorfall



Die Reihenfolge ist ein Grundgerüst. Bei akuter Gefahr, etwa einem laufenden Zahlungsvorgang, wird die Eindämmung vorgezogen. Die Entscheidung über die Reihenfolge wird dokumentiert.

Praxis: Einen Phishing-Vorfall Schritt für Schritt bearbeiten

Lernziel: einen Vorfall in der richtigen Reihenfolge bearbeiten und jede Entscheidung begründen. **Ausgangssituation:** Am Dienstagmorgen meldet eine Kollegin aus dem Vertrieb, dass Kunden Nachrichten mit einem Link erhalten haben, den sie nie verschickt hat. Die IT stellt fest, dass am Vorabend eine Anmeldung von einem unbekannten Standort auf ihrem Konto erfolgte. Im Postfach existiert eine Weiterleitungsregel an eine externe Adresse, die die Kollegin nicht angelegt hat. **Voraussetzungen:** keine technischen. Du brauchst den Ablauf aus diesem Kapitel.
Aufgabenstellung: Beschreibe für jeden Schritt, was du tust, welche Information du dafür brauchst und welche Entscheidung du triffst. Achte auf die Reihenfolge: Eindämmung vor Bereinigung, Protokollsicherung vor Änderungen. **Erwartetes Ergebnis:** Die Weiterleitungsregel wird gesichert, bevor sie gelöscht wird, und das Konto wird gesperrt, bevor Sitzungen beendet werden. Die Mehrfaktor-Methoden werden geprüft, bevor das Kennwort gewechselt wird. Die Kunden werden informiert, sobald der Umfang bekannt ist. **Überprüfung:** Kann ein Dritter anhand deiner Notizen nachvollziehen, warum du in dieser Reihenfolge gehandelt hast? Ist für jede Maßnahme der Zeitpunkt und der Verantwortliche festgehalten?
Fehleranalyse: Häufig wird das Kennwort zuerst gewechselt. Dann besitzt der Angreifer weiter ein gültiges Token und die Regel bleibt bestehen. Die Reihenfolge ist deshalb keine Formalie. **Sicherheitsbetrachtung:** Lösche keine Regeln und Nachrichten, bevor sie dokumentiert sind. Benachrichtige Kunden nicht vor Abstimmung mit der Geschäftsführung und der Rechtsabteilung.

Zusammenfassung

- Ein Phishing-Vorfall umfasst mehr als das eine Konto: Sitzungen, Mehrfaktor-Methoden, Postfachregeln und Geräte gehören dazu.
- Ein Kennwortwechsel allein beendet den Zugang nicht, wenn Tokens oder fremde Mehrfaktor-Methoden bestehen.
- Die Reaktion folgt NIST SP 800-61 Revision 3 und den Funktionen des CSF 2.0.
- Jeder Schritt wird dokumentiert, und die Lessons Learned fließen in die Awareness ein.

Kontrollfragen

1. Warum genügt ein Kennwortwechsel allein nicht, um einen Phishing-Vorfall zu beenden? (leicht)
2. Was ist das Risiko einer Weiterleitungsregel im Postfach? (leicht)
3. Warum werden Protokolle gesichert, bevor Regeln entfernt werden? (mittel)
4. Eine Mehrfaktor-Methode erscheint, die niemand eingerichtet hat. Welche Schritte folgen? (mittel)
5. Die Geschäftsführung will die Kunden sofort informieren, bevor der Umfang feststeht. Wie begründest du eine abgestufte Information, ohne die Transparenz zu verlieren? (schwer)

Lösungshinweise: 1. Ein gültiges Sitzungs-Token oder eine fremde Mehrfaktor-Methode bleibt wirksam. 2. Die Regel leitet Nachrichten still an den Angreifer weiter oder verbirgt sie, sodass der Vorfall unentdeckt bleibt. 3. Das Löschen einer Regel entfernt Beweise. Sicherung und Dokumentation kommen zuerst. 4. Die Methode wird entfernt, das Konto eingeschränkt, Sitzungen beendet, Protokolle gesichert, und der Schadensumfang geprüft. 5. Eine frühe Information sollte sachlich sein und sagen, was bekannt ist, was geprüft wird und wann der nächste Stand kommt. Das Vorgehen wird vorab mit Geschäftsführung und Rechtsabteilung abgestimmt.

Lernzielkontrolle

Du hast dieses Kapitel verstanden, wenn du:

[ ] Anzeichen eines Vorfalls erkennst und ihre Häufung bewertest,

[ ] die Reihenfolge der Reaktion begründest,

[ ] erklärst, warum Sitzungen, Mehrfaktor-Methoden und Regeln zum Vorfall gehören.

Kapitel 7: Praxisprojekt – Phishing-Abwehr in einem Unternehmen

Lernziele

- Du dokumentierst die Ausgangslage einer Organisation und bewertest Bedrohungen nach Wahrscheinlichkeit und Schaden.
- Du prüfst den E-Mail-Schutz einer Domain anhand von SPF, DKIM und DMARC.
- Du entwickelst Awareness-, Melde- und Reaktionsprozesse und priorisierst Maßnahmen für einen Abschlussbericht.

Das Beispielunternehmen

Die Musterfirma heißt Bergmann Werkzeugtechnik GmbH (fiktiv). Sie hat 30 Mitarbeitende in Verwaltung, Vertrieb, Einkauf und IT. Die Windows-Clients sind über Active Directory verwaltet, die E-Mail läuft über Microsoft 365. Die Firma kommuniziert täglich mit Kunden und Lieferanten, und Zahlungen werden über die Buchhaltung freigegeben. Die IT besteht aus zwei Personen, eine davon arbeitet halbtags.

Die Domain der Firma lautet `bergmann-example.de`. Sie ist für das Projekt fiktiv. Für eigene Prüfungen nutzt du eine Domain, die dir gehört.

WARNUNG – Sicherheitsrisiko

Das Projekt arbeitet nur mit fiktiven Daten und mit der eigenen Domain. Die Simulation wird geplant, aber in diesem Projekt nicht versendet. Die Prüfung öffentlicher DNS-Einträge verändert nichts.

Aufgabe 1: Ausgangssituation dokumentieren

Lernziel: die Systeme, Prozesse und Verantwortlichkeiten vollständig erfassen. **Aufgabenstellung:** Lege eine Tabelle mit den Spalten System, Zweck, Verantwortliche, Schutzmaßnahmen und Lücken an. Erfasse mindestens E-Mail, Anmeldung, Zahlungsfreigabe, Dateiablage und Kundenkommunikation. **Erwartetes Ergebnis:** Eine Tabelle mit fünf bis sieben Zeilen. Bei der E-Mail stehen Authentifizierung und Filter, bei der Anmeldung die Mehrfaktor-Methoden, bei der Zahlungsfreigabe der Prozess mit oder ohne zweiten Kanal. **Überprüfung:** Kann jede Lücke einer konkreten Stelle zugeordnet werden? **Fehleranalyse:** Viele Lernende listen nur Technik. Ergänze Prozesse und Verantwortliche, sonst fehlt die Hälfte der Angriffsfläche.

Aufgabe 2: Bedrohungsanalyse durchführen

Lernziel: Bedrohungen nach Wahrscheinlichkeit und Schaden ordnen. **Aufgabenstellung:** Bewerte mindestens fünf Bedrohungen mit einer dreistufigen Skala für Wahrscheinlichkeit (gering, mittel, hoch) und Schaden (gering, mittel, hoch). Verknüpfe jede Bedrohung mit einer Variante aus Kapitel 2.

Musterlösung:

Bedrohung	Variante	Wahrscheinlichkeit	Schaden	Begründung
Gefälschte Rechnung eines Lieferanten	CEO-Fraud, Clone Phishing	hoch	hoch	Rechnungen sind Alltag, Zahlungen laufen über die Buchhaltung
Anmeldung auf gefälschter Microsoft-365-Seite	klassisches Phishing	hoch	hoch	Zugang zu Postfach und Dateien

Bedrohung	Variante	Wahrscheinlichkeit	Schaden	Begründung
Anruf mit Bitte um Einmalcode	Vishing	mittel	hoch	Zugang zum Konto trotz MFA
QR-Code auf Versandetikett	Quishing	mittel	mittel	Zielseite ist nicht prüfbar
Weiterleitungsregel im Postfach	BEC	mittel	hoch	Unbemerkter Datenabfluss

Erwartetes Ergebnis: Die Bewertung ist nachvollziehbar, und die Begründung nennt Gründe aus Aufgabe 1. **Überprüfung:** Ändert sich die Einordnung, wenn sich eine Annahme ändert? Dann ist sie sensitiv und muss dokumentiert werden.

Aufgabe 3: E-Mail-Schutz prüfen

Lernziel: SPF, DKIM und DMARC der eigenen Domain abrufen und nach dem Schema aus Kapitel 4 bewerten. **Voraussetzungen:** Windows-Client mit PowerShell und dem Modul DnsClient. Die Abfragen lesen nur öffentliche Einträge. **Aufgabenstellung:** Rufe die Einträge für die Domain der Firma ab. Im Projekt steht für `bergmann-example.de` nur das Ergebnis, nicht die Abfrage, weil die Domain fiktiv ist. Führe die Abfragen für deine eigene Test-Domain aus.

Befehle zu Aufgabe 3

```
PS> Resolve-DnsName -Name <domain> -Type TXT | Where-Object {
    $_.Strings -match '^v=spf1' }
PS> Resolve-DnsName -Name _dmarc.<domain> -Type TXT
PS> Resolve-DnsName -Name <selector>._domainkey.<domain> -Type TXT
PS> Resolve-DnsName -Name <selector>._domainkey.<domain> -Type
    CNAME
```

Erklärung: Die erste Abfrage liefert den SPF-Eintrag, den der Filter auf Einträge mit `v=spf1` begrenzt. Die zweite zeigt die DMARC-Richtlinie unter

`_dmarc`. Die dritte liefert den DKIM-Schlüssel unter dem Selector. Den Selector entnimmst du dem Feld `s=` in einer signierten Nachricht der Domain. Bei Microsoft 365 sind die Selektoren häufig `selector1` und `selector2`. Verweist der Selector auf einen CNAME, folgst du dem Ziel mit der TXT-Abfrage. Prüfe beides in der Herstellerdokumentation.

Musterlösung für die Firma (fiktive Ergebnisse):

- SPF: `v=spf1 include:spf.protection.outlook.com -all` (der Include-Eintrag steht hier als typisches Beispiel für Microsoft 365; prüfe ihn in der Herstellerdokumentation). Der Eintrag ist vorhanden und endet hart. Befund: Der Include-Eintrag für weitere Versandsysteme fehlt, etwa für das Ticketsystem. Diese Systeme würden abgewiesen.
- DMARC: `v=DMARC1; p=none; rua=mailto:dmarc@bergmann-example.de`. Die Richtlinie beobachtet nur. Befund: Kein Schutz durch Ablehnung. Empfehlung: Auswertung der Berichte, dann Übergang zu `quarantine`.
- DKIM: Schlüssel für beide Selektoren vorhanden. Befund: keiner.

Erwartetes Ergebnis: Die Bewertung nennt je Baustein den Befund und einen konkreten Schritt. **Fehleranalyse:** Eine Abfrage liefert nichts? Prüfe den Domainnamen und den Selector. Ein fehlender Eintrag ist ein Befund, kein Fehler der Abfrage. **Sicherheitsbetrachtung:** Verändere in der eigenen Domain nur, was du verantwortest. Die fiktive Domain der Firma gehört niemandem in der Übung.

Aufgabe 4: Awareness-Konzept und Meldeprozess

Lernziel: ein Konzept mit Zielgruppen, Maßnahmen, Messgrößen und Meldeweg erstellen. **Aufgabenstellung:** Erstelle das Konzept nach dem Muster aus Kapitel 5. Ergänze einen Meldeprozess mit Schritten, Verantwortlichen und Rückmeldung.

Musterlösung (Auszug):

- Zielgruppe Buchhaltung: Schulung zur Zahlungsfreigabe, feste Regel für neue Empfänger mit Prüfung über bekannten Kontakt. Messgröße: Anteil geprüfter Zahlungen an neuen Empfängern.
- Alle Mitarbeitenden: vierteljährliche Kurzschulung mit Beispielen aus dem Alltag, Passkey-Einführung für Microsoft 365. Messgröße: Anteil

registrierter phishing-resistenter Methoden.

• Meldeweg: Meldeschaltfläche und Adresse des IT-Teams, Bestätigung innerhalb eines Arbeitstages. Messgröße: Zeit bis zur Meldung und Zahl der Meldungen.

Erwartetes Ergebnis: Der Meldeprozess ist in vier Schritten beschrieben: melden, bestätigen, prüfen, Rückmeldung. **Überprüfung:** Kann die Buchhaltung den Prozess ohne Rückfrage anwenden?

Aufgabe 5: Autorisierte Phishing-Simulation planen

Lernziel: eine Simulation planen, die Genehmigung, Umfang und Datenschutz berücksichtigt. Die Durchführung ist nicht Teil des Projekts. **Aufgabenstellung:** Beschreibe Ziel, Zielgruppe, Zeitraum, Szenario, Freigabe, Auswertung und Datenschutz. Lege fest, welche Daten erhoben werden und wann sie gelöscht werden.

Musterlösung (Auszug):

• Ziel: Prüfen, ob die Zahlungsfreigabe über den zweiten Kanal eingehalten wird. Es werden keine Zugangsdaten erhoben.

• Freigabe: schriftlich durch die Geschäftsführung und den Betriebsrat, Abstimmung mit dem Datenschutzbeauftragten.

• Daten: nur aggregierte Auswertung, keine namentlichen Ergebnisse im Bericht, Löschung nach Abschluss.

Erwartetes Ergebnis: Ein Planungsdokument mit Freigabevermerk, das ohne Verweis auf technische Anleitungen auskommt.
Sicherheitsbetrachtung: Die Planung enthält keine Nachricht, keine Zielliste und keine technische Anleitung zum Versand.

Aufgabe 6: Ergebnisse auswerten

Lernziel: Kennzahlen korrekt lesen und Fehlinterpretationen vermeiden. **Aufgabenstellung:** Eine fiktive Auswertung zeigt 30 Empfangende, 4 Klicks auf den Link, 1 Dateneingabe, 9 Meldungen. Bewerte die Zahlen.

Musterlösung: Die Klickrate (4 von 30) ist eine schwache Größe, weil ein Klick den Link nicht bewertet. Die Meldungen (9) sind eine stärkere Größe, denn sie zeigen den gewünschten Reflex. Die Dateneingabe (1) ist ein

Befund für Schulung und Technik, etwa phishing-resistente Anmeldung für diesen Personenkreis. Die Zeit bis zur Meldung ist im Projekt nicht erhoben und sollte beim nächsten Durchgang erfasst werden.

Erwartetes Ergebnis: Die Bewertung nennt drei Kennzahlen mit Aussage und Grenze. **Fehleranalyse:** Die Auswertung als Strafliste über einzelne Personen ist unzulässig. Berichte nur aggregiert.

Aufgabe 7: Reaktionsablauf, Priorisierung und Abschlussbericht

Lernziel: einen Reaktionsablauf entwickeln, Maßnahmen priorisieren und den Bericht gliedern. **Aufgabenstellung:** Entwickle einen Reaktionsablauf nach dem Muster aus Kapitel 6. Priorisiere die Maßnahmen aus den Aufgaben 3 und 4 nach Nutzen und Aufwand. Schreibe den Abschlussbericht mit den Abschnitten Ausgangslage, Befunde, Maßnahmen, Restrisiken und Grenzen.

Musterlösung (Priorisierung):

1. Hoch, geringer Aufwand: Prüfung über bekannten Kanal bei Zahlungen an neue Empfänger.
2. Hoch, mittlerer Aufwand: DMARC-Berichte auswerten, danach `quarantine` einführen.
3. Hoch, mittlerer Aufwand: phishing-resistente Methoden für Administrations- und Buchhaltungskonten.
4. Mittel: fehlende Include-Einträge im SPF-Record ergänzen, nach Prüfung aller Versandsysteme.
5. Mittel: Meldeprozess veröffentlichen und Rückmeldungen einführen.

Restrisiken: Die IT ist personell knapp, Simulationen sind noch nicht durchgeführt, Kunden können Fälschungen unabhängig von der eigenen Domain erhalten.

Erwartetes Ergebnis: Ein Bericht von zwei bis vier Seiten, der jede Maßnahme mit Begründung und Verantwortlichem nennt.

Bewertungskriterien

Kriterium	erfüllt	teilweise	nicht erfüllt
Ausgangslage vollständig und belegt	alle Systeme mit Verantwortlichen und Lücken	einzelne Systeme fehlen	nur Technik beschrieben
Bedrohungen begründet bewertet	jede Bewertung mit Grund	Begründungen fehlen teilweise	Bewertung ohne Begründung
E-Mail-Prüfung nach dem Schema	jeder Baustein mit Befund und Schritt	Bausteine unvollständig	keine Befunde
Awareness mit Messgrößen	Maßnahmen mit Messgröße	Messgrößen fehlen teilweise	nur Schulungen
Simulation mit Freigabe und Datenschutz	vollständig geplant	Freigabe offen	Planung ohne Freigabe
Priorisierung begründet	Nutzen und Aufwand genannt	nur Reihenfolge	keine Priorisierung

Kontrollfragen

1. Warum wird im Projekt die Domain der Firma fiktiv gelassen, und welche Domain nutzt du stattdessen? (leicht)
2. Warum ist die Klickrate in der Auswertung eine schwache Größe? (mittel)
3. Welche Maßnahme aus der Priorisierung hat den größten Nutzen bei geringem Aufwand, und warum? (mittel)
4. Die DMARC-Richtlinie steht auf `none`. Welche Folge hat das für die Firma, und welcher Schritt folgt? (mittel)
5. Die Geschäftsführung will die Simulation sofort versenden, bevor die Freigabe vorliegt. Wie begründest du den Stopp, und was schlägst du vor? (schwer)

Lösungshinweise: 1. Die Domain der Firma ist fiktiv. Für die eigene Prüfung nutzt du eine Domain, die dir gehört. 2. Ein Klick zeigt Neugier oder Versehen, nicht die Bewertung der Nachricht. Die Meldungen sind aussagekräftiger. 3. Die Prüfung über den bekannten Kanal bei Zahlungen an neue Empfänger. Sie kostet wenig und schützt vor dem häufigsten Schaden. 4. Die Richtlinie beobachtet nur und verhindert nichts. Der nächste Schritt ist die Auswertung der Berichte, danach die Umstellung auf `quarantine`. 5. Ohne Freigabe ist die Simulation ein unbefugter Zugriff auf Beschäftigte und Daten. Vorschlag: Freigabe einholen, Planung vorlegen, Termin festlegen.

Lernzielkontrolle

Du hast das Projekt bestanden, wenn du:

- [ ] die Ausgangslage und Bedrohungen einer Organisation begründet bewertest,
- [ ] SPF, DKIM und DMARC einer Domain abrufst und nach dem Schema bewertest,
- [ ] Awareness, Meldeweg und Simulation planst und die Maßnahmen priorisierst.

Recht und Verantwortung

Dieser Abschnitt gibt allgemeine Informationen. Er ersetzt keine Rechtsberatung. Vor einer konkreten Maßnahme klärst du die Rechtslage mit dem Datenschutzbeauftragten, der Rechtsabteilung oder einer fachkundigen Stelle.

Autorisierung als Grundlage

Jede Übung in diesem Buch findet in eigenen oder ausdrücklich freigegebenen Umgebungen statt. Eine Simulation gegen Mitarbeitende eines Unternehmens braucht eine schriftliche Freigabe der Verantwortlichen. Die Freigabe nennt den Umfang, den Zeitraum, die Zielgruppe und die Auswertung. Ohne sie wird aus einer Übung ein unbefugter Zugriff auf fremde Systeme oder Personen.

Datenschutz

Die Datenschutz-Grundverordnung (DSGVO) verlangt, personenbezogene Daten angemessen zu schützen. Artikel 32 verpflichtet Verantwortliche zu geeigneten technischen und organisatorischen Maßnahmen. Artikel 33 regelt die Meldung von Verletzungen des Schutzes personenbezogener Daten an die Aufsichtsbehörde, in der Regel innerhalb von 72 Stunden nach Bekanntwerden. Die Pflicht gilt, wenn ein Phishing-Vorfall personenbezogene Daten betrifft.

Ergänzend regelt das Bundesdatenschutzgesetz (BDSG) den Beschäftigtendatenschutz, insbesondere in § 26. Die Vorschrift war in den letzten Jahren Gegenstand gerichtlicher Entscheidungen. Prüfe deshalb die jeweils geltende Fassung. Protokolle, die das Verhalten einzelner Mitarbeitender zeigen, etwa Klickdaten aus Simulationen, sind personenbezogen. Speicherung, Zweck und Löschfristen sind festzulegen.

Arbeitnehmerdatenschutz und Mitbestimmung

Simulationen und Protokollauswertungen betreffen Beschäftigte. Je nach Ausgestaltung kann der Betriebsrat mitbestimmen, etwa wenn technische Einrichtungen geeignet sind, Verhalten zu überwachen. Die Mitbestimmung bei technischen Überwachungseinrichtungen ist im Betriebsverfassungsgesetz geregelt. Eine frühe Abstimmung vermeidet Konflikte.

Strafrechtliche Grenzen

Das Strafgesetzbuch kennt Vorschriften, die unbefugtes Ausspähen und Abfangen von Daten sowie die Veränderung von Daten unter Strafe stellen (§ 202a, § 202b und § 303a). Auch Computerbetrug (§ 263a) ist ein relevanter Tatbestand. Die Grenze verläuft dort, wo Zugriff ohne Berechtigung erfolgt. Eine autorisierte Simulation ist keine Straftat, eine Simulation ohne Freigabe kann es sein. Die Einzelfallbewertung erfolgt durch die zuständigen Stellen.

Verantwortungsvolle Sicherheitsforschung

Wer Schwachstellen prüft, erhält Zugang zu Informationen, die nicht für ihn bestimmt sind. Verantwortungsvoll handelt, wer nur das prüft, wofür er beauftragt ist, Funde meldet, ohne sie zu verbreiten, und Daten nach der Auswertung löscht. Die Grenze verschiebt sich nicht durch gute Absichten.

Anhang

Muster eines Phishing-Incident-Berichts

1. **Vorfall:** Kennung, Datum und Uhrzeit der Meldung, meldende Person, Verantwortliche.
2. **Beschreibung:** Was wurde gemeldet, was wurde beobachtet. Nur Beobachtungen, keine Schlussfolgerungen.
3. **Betroffene:** Anzahl der Konten und Systeme, Rollen der Personen, Daten, die betroffen sein könnten.
4. **Zeitlicher Ablauf:** Erste Anzeichen, Eindämmung, Wiederherstellung, jeweils mit Zeitpunkt.
5. **Maßnahmen:** Durchgeführte Schritte mit Verantwortlichem und Ergebnis.
6. **Ursache:** Angriffsweg, soweit belegt. Nicht belegte Punkte als offen kennzeichnen.
7. **Meldepflichten:** Prüfung durch den Datenschutzbeauftragten, Fristen, Entscheidung und Begründung.
8. **Lessons Learned:** Ursachen, Maßnahmen, Zuständigkeiten und Termine.

Muster einer Awareness-Richtlinie

1. **Zweck und Geltungsbereich:** Warum die Richtlinie gilt, für wen.
2. **Pflichten der Mitarbeitenden:** Verdächtige Nachrichten melden, Zahlungen nur über den Prozess freigeben, keine Zugangsdaten auf Anmeldeseiten eingeben, die nicht aus dem vertrauten Zugang aufgerufen wurden.
3. **Meldeweg:** Meldefunktion, Adresse des IT-Teams, Rückmeldung innerhalb einer festgelegten Frist.
4. **Schulungen:** Turnus, Zielgruppen, Nachweis der Teilnahme.
5. **Authentifizierung:** Pflicht zur Mehrfaktor-Authentifizierung, Vorgabe phishing-resistenter Verfahren für bestimmte Rollen.

6. **Konsequenzen:** Keine Sanktion für gemeldete Fehler. Verstöße gegen Prozesse werden nach der internen Ordnung behandelt.

7. **Überprüfung:** Turnus der Überprüfung und zuständige Stelle.

Checkliste zur E-Mail-Prüfung

[ ] Absender: Anzeigename und Adresse stimmen überein und sind bekannt.

[ ] Umschlag und Header: Return-Path, Reply-To und Message-ID passen zur Domain des Absenders.

[ ] Authentication-Results: SPF, DKIM und DMARC sind bestanden oder erklärbar fehlgeschlagen.

[ ] Anliegen: Wird etwas verlangt, das über einen Prozess freigegeben werden müsste?

[ ] Zeitdruck oder Geheimhaltung: Wird eine Entscheidung unter Druck verlangt?

[ ] Kanal: Ist ein zweiter, bekannter Kanal zur Prüfung verfügbar?

[ ] Links: Ziel vor dem Klick prüfen, QR-Codes nur aus erwarteten Vorgängen scannen.

[ ] Anhänge: Nur öffnen, wenn der Vorgang erwartet war.

[ ] Meldung: Nachricht melden, nicht weiterleiten und nicht antworten.

Glossar

Alignment (Ausrichtung): Prüfung, ob die authentifizierte Domain zur Domain im `From`-Feld passt. Kapitel 4.

Anzeigename (Display Name): der Name, der im Lesefenster neben der Adresse steht. Er lässt sich frei setzen. Kapitel 3.

BEC (Business Email Compromise): Betrug über ein echtes, kompromittiertes E-Mail-Konto. Kapitel 2.

CEO-Fraud: Betrug, bei dem sich der Angreifer als Geschäftsführung ausgibt, um eine Zahlung zu veranlassen. Kapitel 2.

Clone Phishing: Nachricht, die eine frühere echte Nachricht nachbildet und Anhang oder Link ersetzt. Kapitel 2.

DKIM (DomainKeys Identified Mail): Signatur einer Nachricht durch die sendende Domain, geprüft über einen öffentlichen Schlüssel im DNS. Kapitel 4.

DMARC: Richtlinie, die SPF und DKIM mit dem Absender im `From`-Feld verbindet und Berichte ermöglicht. Kapitel 4.

Envelope (Umschlag): Absenderangabe des SMTP-Dialogs für die Zustellung, getrennt vom Header. Kapitel 3.

FIDO2 und WebAuthn: Verfahren, bei dem ein Schlüssel nur für die echte Domain Signaturen erzeugt. Kapitel 5.

MFA (Mehrfaktor-Authentifizierung): Anmeldung mit zwei oder mehr unabhängigen Nachweisen. Kapitel 5.

Passkey: Anmeldeschlüssel nach dem FIDO-Verfahren, der gerätegebunden oder synchronisiert sein kann. Kapitel 5.

Pretexting: erfundene Begründung, mit der sich ein Angreifer legitimiert. Kapitel 1.

Received-Zeile: Eintrag im Header, den jeder weiterleitende Server hinzufügt. Kapitel 3.

Return-Path: Adresse für Zustellfehler, im fertigen Header vom Empfangsserver eingetragen. Kapitel 3.

Quishing: Phishing über QR-Codes. Kapitel 2.

Selector: Name des DKIM-Schlüssels, der im Feld `s=` der Signatur steht. Kapitel 4.

SMTP: Protokoll für den Versand von E-Mails, beschrieben in RFC 5321. Kapitel 3.

SPF (Sender Policy Framework): DNS-Eintrag, der die zugelassenen Versandsysteme einer Domain nennt. Kapitel 4.

Smishing: Phishing per SMS oder Nachrichtendienst. Kapitel 2.

Sitzungs-Token: nach einer Anmeldung ausgestellter Nachweis, der die Sitzung trägt. Kapitel 6.

Spear-Phishing: auf eine bestimmte Person zugeschnittenes Phishing. Kapitel 2.

Spoofing: Vortäuschen eines falschen Absenders. Kapitel 3.

Vishing: Phishing am Telefon. Kapitel 2.

Whaling: Spear-Phishing mit einer Führungskraft als Ziel. Kapitel 2.

Quellenverzeichnis

Die Quellen sind nach Art gruppiert. Angegeben sind Herausgeber, Titel, Adresse und Abrufdatum, soweit die Quelle online geprüft wurde. Bei Quellen ohne Abrufdatum wurde der Titel aus Fachwissen übernommen und steht noch zur Prüfung aus.

Normen und Spezifikationen der IETF

• IETF, RFC 7208: Sender Policy Framework (SPF) for Authorizing Use of Domains in Email. Adresse: rfc-editor.org/rfc/rfc7208. Abgerufen am 11. November 2026 über die Websuche, Titel bestätigt.

• IETF, RFC 6376: DomainKeys Identified Mail (DKIM) Signatures. Adresse: rfc-editor.org/rfc/rfc6376. Abgerufen am 11. November 2026 über die Websuche, Titel bestätigt.

• IETF, RFC 7489: Domain-based Message Authentication, Reporting, and Conformance (DMARC). Adresse: rfc-editor.org/rfc/rfc7489. Abgerufen am 11. November 2026 über die Websuche, Titel bestätigt. Hinweis: Nachfolgespezifikation „DMARCbis“ liegt als Entwurf vor, Status bei der IETF prüfen.

• IETF, RFC 5321: Simple Mail Transfer Protocol. Titel aus Fachwissen, Abruf ausstehend.

• IETF, RFC 5322: Internet Message Format. Titel aus Fachwissen, Abruf ausstehend.

• IETF, RFC 8601: Message Header Field for Indicating Message Authentication Status. Titel aus Fachwissen, Abruf ausstehend.

NIST

• NIST, Special Publication 800-61 Revision 3: Incident Response Recommendations and Considerations for Cybersecurity Risk Management. Veröffentlichung April 2025, ersetzt Revision 2. Adresse der Pressemitteilung: csrc.nist.gov/news/2025/nist-revises-sp-800-61. Abgerufen am 11. November 2026.

• NIST, Special Publication 800-63B: Digital Identity Guidelines, Authentication and Lifecycle Management. Angaben zu Revision 4 wurden über Sekundärquellen geprüft, das Originaldokument ist maßgeblich. Abruf des Originals ausstehend.

Herstellerdokumentation

• Microsoft Learn: Resolve-DnsName, Modul DnsClient. Adresse: learn.microsoft.com/powershell/module/dnsclient/resolve-dnsname. Abgerufen am 11. November 2026 über die Websuche.

• Microsoft: Herstellerdokumentation zu Microsoft 365 für DKIM-Selektoren und SPF-Einträge. Titel und Adresse ausstehend, vor Verwendung nachzuschlagen.

Recht

• Verordnung (EU) 2016/679 (Datenschutz-Grundverordnung), Artikel 32 und 33. Titel aus Fachwissen, Abruf ausstehend.

• Bundesdatenschutzgesetz, § 26. Titel aus Fachwissen, Fassung vor Verwendung prüfen.

• Strafgesetzbuch, §§ 202a, 202b, 263a und 303a. Titel aus Fachwissen, Abruf ausstehend.

• Betriebsverfassungsgesetz, § 87 Absatz 1 Nummer 6. Titel aus Fachwissen, Abruf ausstehend.

Verzeichnis der Befehle

Befehl	Zweck	Kapitel
`Resolve-DnsName -Name <domain> -Type TXT`	TXT-Einträge einer Domain abrufen (SPF, DMARC, DKIM)	4, 7

Befehl	Zweck	Kapitel
`Where-Object { $_.Strings -match '^v=spf1' }`	SPF-Eintrag aus den Ergebnissen filtern	4, 7
`Resolve-DnsName -Name _dmarc.<domain> -Type TXT`	DMARC-Richtlinie abrufen	4, 7
`Resolve-DnsName -Name <selector>._domainkey.<domain> -Type TXT`	DKIM-Schlüssel abrufen	4, 7
`Resolve-DnsName -Name <selector>._domainkey.<domain> -Type CNAME`	DKIM-Selector als CNAME abrufen, etwa bei Microsoft 365; danach TXT-Abfrage auf das Ziel	4, 7
`nslookup.exe -type=TXT <name>`	TXT-Einträge über das Programm abrufen	4
`Connect-ExchangeOnline` (Exchange Online PowerShell)	Verbindung für die Postfachprüfung herstellen	6
`Get-InboxRule -Mailbox <postfachadresse>` (Exchange Online PowerShell)	Postfachregeln eines Postfachs prüfen, vor Verwendung in der eigenen Umgebung prüfen	6

Stichwortverzeichnis

Die Verweise führen auf Kapitel.

Alignment 4 · Anzeigename 3 · BEC 2 · BDSG Recht und Verantwortung · Clone Phishing 2 · CEO-Fraud 2, 7 · DKIM 3, 4, 7 · DMARC 3, 4, 7 · DSGVO

Recht und Verantwortung · Envelope 3 · FIDO2 5 · Header 3 · MFA 5, 6 · Meldeweg 5, 6 · NIST 5, 6 · Passkey 5 · Pretexting 1 · Quishing 2 · Received 3 · Return-Path 3 · Selector 4, 7 · SMTP 3 · SPF 3, 4, 7 · Smishing 2 · Spear-Phishing 2 · Spoofing 3 · Token 6 · Vishing 2 · Whaling 2

SOCIAL ENGINEERING & PHISHING-ABWEHR

Vom Psychologischen Hebel bis zur wirksamen Abwehr im Unternehmen

Dieses Praxishandbuch erklärt, wie Angreifer Menschen manipulieren, und zeigt, wie man Phishing, CEO-Fraud und Vishing erkennt. Technische Merkmale von E-Mails, SPF, DKIM und DMARC gehören ebenso dazu wie Prozesse, Awareness und die Reaktion auf einen Vorfall.

DAS ERWARTET DICH

- Psychologische Hebel und typische Angriffsmuster erkennen
- Phishing, Spear-Phishing, CEO-Fraud, Vishing und Quishing unterscheiden
- E-Mail-Header und Authentifizierung mit SPF, DKIM und DMARC verstehen
- Awareness-Konzepte und Meldewege planen
- Reaktion auf einen Phishing-Vorfall strukturieren

Für wen?

Einsteiger, IT-Administratoren, angehende Fachinformatiker und alle, die in einer Organisation für Awareness und E-Mail-Sicherheit Verantwortung tragen.

Praxishandbuch · Autor: Eugen Becker · Ausgabe November 2026

Hinweis: Übungen nur mit erfundenen Beispielen und in eigenen oder ausdrücklich freigegebenen Umgebungen. Befehle vor dem Ei